INCIDENT RESPONSE · NETWORK PLAYBOOK

Network Incident Response Playbook

Arkime, Splunk and core router commands

Prepared by Dan · October 2026

Contents

Purpose and how to use this playbook 3

Network terrain and baseline 4

1 **Initial Access** TA0001 7
1.1 Valid Account: Unusual Source 7
1.2 Phishing Email Delivered and Opened 8
1.3 Exploit of a Public-Facing Application 9
1.4 Unauthorised Device on the Network 10

2 **Execution** TA0002 11
2.1 Remote Execution: WMI and DCOM 11
2.2 Remote Execution: Service Creation (PsExec-Style) 12

3 **Persistence** TA0003 13
3.1 Web Shell on a Web Server 13
3.2 Persistence on a Core Router 14
3.3 New Accounts or Privileged Group Changes 15

4 **Privilege Escalation** TA0004 16
4.1 Privileged Account: Unexpected Source 16
4.2 Group Policy or Domain Policy Modified 17

5 **Defense Evasion** TA0005 18
5.1 Logging or Sensor Tampering 18
5.2 Firewall, Access Control or Routing Change 19
5.3 Traffic on Non-Standard Ports or Mismatched Protocols 20

6 **Credential Access** TA0006 21
6.1 Brute Force and Password Spraying 21
6.2 Kerberoasting and AS-REP Roasting 22
6.3 Domain Credential Theft: DCSync and AD Database Copy 23
6.4 Credential Interception on the Network 24

7 **Discovery** TA0007 25
7.1 Network Scanning and Remote System Discovery 25
7.2 Active Directory and Domain Enumeration 26
7.3 Network Share and File Discovery 26

8 **Lateral Movement** TA0008 28
8.1 Remote Services: Remote Desktop Protocol 28
8.2 Remote Services: SMB and Windows Admin Shares 29
8.3 Remote Services: WinRM and PowerShell Remoting 29
8.4 Remote Services: SSH 30
8.5 Pass-the-Hash, Pass-the-Ticket and NTLM Relay 31
8.6 Movement Between Segments Outside Agreed Flows 32

9 **Collection** TA0009 33
9.1 Bulk Reads from Shares or Databases 33
9.2 Data Staged and Archived 34
9.3 Email Collection 34

10 **Command and Control** TA0011 36
10.1 Application Layer Protocol: Web Beaconing 36
10.2 Application Layer Protocol: DNS Command and Control and Tunnelling 37
10.3 Remote Access Software 37
10.4 Protocol Tunnelling and Proxy 38

11 **Exfiltration** TA0010 40
11.1 Exfiltration Over Web Service: Cloud Storage 40
11.2 Exfiltration Over C2 Channel 41
11.3 Exfiltration Over Alternative Protocol 41

12 **Impact** TA0040 43
12.1 Data Encrypted for Impact: Mass File Changes Over SMB 43
12.2 Mass Deployment from the Domain Controller or an Admin Host 44
12.3 Denial of Service or Link Saturation 44
12.4 Application Data Manipulation 45

13 **Network Devices and Boundary** ATT&CK NETWORK DEVICES 47
13.1 Core Router: Management Access from an Unexpected Source 47
13.2 Core Router: Tunnels, Redirection or Packet Capture 48

Purpose and how to use this playbook

This playbook gives network analysts step-by-step Arkime, Splunk and core router actions for each MITRE ATT&CK (Enterprise) tactic that can be observed on the network. Find the tactic that matches the alert, pick the closest event, and work its steps in order. It is the companion to the Host-Based Incident Response Playbook. Events use the same tactic sections, and each event lists the host playbook events to run on the hosts involved.

> **Scope:** network traffic and network device analysis for workstations, servers and core routers. Host investigation is in the Host-Based Incident Response Playbook. Email gateway and identity provider investigation are referenced but not covered here.

Reconnaissance (TA0043) and Resource Development (TA0042) are left out because they happen before the adversary reaches the network. Section 13 covers the core routers.

STANDARD RESPONSE FLOW (APPLIES TO EVERY EVENT)

Triage 1

Validate the alert. Find the source and destination, and how many hosts are involved.

Collect 2

Run the event's Arkime and Splunk searches. Tag and export packet captures first, as they age out.

Analyse 3

Build a timeline around the trigger time. Identify what the source connected to, what moved and which accounts were used.

Contain 4

Apply the event's firewall rules on the core routers. Ask the host team to isolate the host through the host playbook.

Eradicate and recover 5

With the host team, remove persistence, reset credentials and restore changed device configurations. Re-check traffic.

Document 6

Record findings, indicators, search strings and decisions in the case.

HOW EACH EVENT IS LAID OUT

Trigger	What fired: the alert or observation that sends you to this event.
ATT&CK / Priority	Technique IDs to match alerts, the host playbook events to run on the hosts, and the starting priority with the conditions that raise it.
Response steps	What to do, in order. Each step lists the logs to check and the Arkime, Splunk or router commands to run.
Containment	Firewall rules and other network actions to stop the activity once evidence is collected, written in plain English.
Escalate if	Conditions that take the incident beyond the analyst on shift.
Evidence to record	What must go into the case notes.
Notes	The machine types the event applies to, what is at risk, the likely objective, the likely next move, and possible indicators.

READING THE RESPONSE STEPS

- **Logs** Log sources and event IDs to check.
- **Arkime** Query for the Sessions search bar. Set the time range to start 24 hours before first detection. SPI View and Connections are Arkime views.
- **Splunk** Single-line search to paste into Splunk. Index and field names are placeholders; rename them to match your environment.
- **Router** Command to run on a core router (Vyatta syntax; adapt to your router platform). Run only with the incident lead's approval and copy the configuration first.
- **Host** A request to the host team or another owner, with the host playbook event to run.

Replace placeholders before running them: `<host_ip>`, `<src_ip>`, `<dst_ip>`, `<user>`, `<local_range>` and the others listed in Network terrain and baseline. Arkime field names and Splunk event fields match common builds; confirm them in your own environment.

PRIORITY LEVELS

CRITICAL Act immediately and escalate. **HIGH** Start response now. **MEDIUM** Investigate in the current shift; raise if conditions are met.

Network terrain and baseline

Complete this section before an incident and keep it current. The indicators in each event are deviations from it.

TRAFFIC PATH

Network segments → Core routers → Gateway → Off the network

All segments route through the core routers. Traffic leaving the network passes through the gateway. Capture traffic at the gateway so that all off-network traffic is visible to Arkime.

NETWORK SEGMENTS

Record each segment, its address range and the data it holds. The rows below are examples; replace them with the segments in your network.

Segment	Placeholder	Function	Data or capability at risk
User workstations	`<user_range>`	Staff workstations and user devices	User accounts, mail and local data
Servers	`<server_range>`	Domain controller, file, mail, web, database and application servers	Credentials, shared data and core services
IT management	`<mgmt_range>`	IT admin workstations and jump hosts	Administrative access to servers and network devices
Sensitive data	`<sensitive_range>`	Systems that hold records of high value	Records that should not leave the network
Core routers	`<core_router_ip>`	Routing and rules between segments	All traffic between segments

NORMAL TRAFFIC BETWEEN SEGMENTS

These flows are assumptions. Confirm them against your network documentation and correct them before use. Every flow not listed is unexpected.

Source	Expected destinations	Should never
User workstations	Server segment services; off-network through the gateway	Connect to other user workstations; start remote login to servers
Servers	Directory, name resolution, time, logging and update services	Start connections to user workstations; browse off the network except patching
IT management	All servers on management ports; core routers	Receive connections from user workstations; browse off the network
Sensitive data systems	Server segment services; agreed lookups from user segments	Connect to any other segment; send traffic off the network
Public-facing servers	Backend database; users on ports 80 and 443	Start connections to internal segments except the backend database

SENSOR COVERAGE

Confirm Arkime capture on: the gateway (all off-network traffic); the core router link to each segment (all traffic between segments); and the server segment. Traffic between hosts in the same segment and VLAN is often not captured. Record any gap here and cover it with Windows logs in Splunk.

SPLUNK INDEXES USED

`net` firewall and router connection logs · `wineventlog` Windows Security and System logs from domain controllers and servers · `web` web access logs · `mail` mail logs · `dns` name resolution logs · `network_devices` core router syslog and authentication. Rename to match your environment.

ASSET BASELINE

Asset	Connects to	Receives connections from	Should never
User workstations	Domain controller (53, 88, 135, 389, 445, 49152+), file server (445), web server (80, 443), mail server (25, 587)	IT admin workstations only	Connect to other workstations; start remote login to servers
IT admin workstations	All servers on management ports (22, 445, 3389, 5985, 5986), core routers (22, 443)	Almost nothing	Browse off the network; receive remote login or SMB from user workstations
File server	Domain controller	User and admin workstations (445)	Start connections off the network; start SMB or remote login to workstations
Web server	Backend database, domain controller if joined	Users (80, 443), admin workstations	Start connections off the network except patching; start connections to internal segments
Domain controller	Other domain controllers, upstream name resolution and time	All internal hosts (53, 88, 135, 389, 445, 636, 3268)	Browse off the network; start SMB or remote login to workstations; replicate with non-domain controllers
Mail server	Off-network mail (25), mail clients, domain controller	Mail clients (25, 587, 465, 993)	Relay for unauthenticated hosts; send large volumes to new external domains
Core routers	Logging, time, authentication servers	IT admin workstations only (22, 443, SNMP)	Accept management from user segments; send configuration to unknown hosts

PLACEHOLDERS

Placeholder	Meaning	Placeholder	Meaning
`<host_ip>` , `<host_name>`	Host under investigation	`<dc_ip>` , `<other_dc_ips>`	Domain controller, other domain controllers
`<src_ip>` , `<dst_ip>`	Source and destination of the activity	`<mail_server_ip>` , `<mailbox>`	Mail server, mailbox in question
`<user>` , `<account>`	Account name	`<file_server_ip>` , `<file_server_name>`	File server
`<admin_accounts>`	List of privileged account names	`<web_server_ip>` , `<db_server_ip>` , `<app_server_ip>`	Web, database and application servers
`<local_range>`	Address range covering all local segments	`<dns_server_ip>` , `<dhcp_server_ip>`	Internal name resolution and DHCP servers
`<segment_range>` , `<other_segment_range>`	Address ranges of two segments	`<core_router_ip>` , `<repository_ip>`	Core router, router update repository
`<mgmt_range>`	IT admin workstations	`<deploy_ip>`	Approved web deployment host
`<yyyy-mm-dd hh:mm>`	Date and time (UTC)		

Placeholder	Meaning	Placeholder	Meaning
`<deploy_ip>`	Approved web deployment host	`<yyyy-mm-dd hh:mm>`	Date and time (UTC)

1 TA0001 Initial Access

The adversary gets a first foothold. On the network this shows as a new source reaching an exposed service, or a trusted account used from an unusual place. Confirm the access, find what the source did next, and block further entry.

1. INITIAL ACCESS · TA0001

1.1 Valid Account: Unusual Source

PRIORITY **HIGH** ATT&CK T1078 Valid Accounts | T1133 External Remote Services HOST PLAYBOOK 1.1

Critical if the account is privileged or the logon reached a server.

TRIGGER

A successful logon from a source outside the account's normal pattern: an address outside the local ranges, a new address in the account's segment, impossible travel between two locations, or a logon at an unusual hour. Off-network access arrives through the gateway.

RESPONSE STEPS

1. **Confirm the logon and its source.**
   - Logs: Windows Security 4624 (logon type 3 network, 10 remote desktop) and 4625 failures on the domain controller and the target host. Gateway and core router connection logs.
   - Splunk: `index=wineventlog EventCode=4624 Account_Name=<user> | stats count min(_time) as first max(_time) as last by Source_Network_Address Logon_Type host | convert ctime(first) ctime(last)`
   - Arkime: `ip.src==<src_ip> && ip.dst==<host_ip>` then sort by Start Time, oldest first.
2. **Check whether the source address is new for this user.**
   - Splunk: `index=wineventlog EventCode=4624 Account_Name=<user> earliest=-30d | stats min(_time) as first by Source_Network_Address | where first>relative_time(now(),"-48h") | convert ctime(first)`
3. **Check for failed attempts before the success.**
   - Logs: Windows Security 4625, 4771 and 4776 on the domain controller.
   - Splunk: `index=wineventlog EventCode=4625 Account_Name=<user> | stats count by Source_Network_Address | sort -count`
4. **List everything the source connected to after the logon.**
   - Arkime: `ip.src==<src_ip>` then open Connections and SPI View on `ip.dst`, `port.dst` and `protocols`.
   - Splunk: `index=net src_ip=<src_ip> | stats count values(dest_port) as ports min(_time) as first by dest_ip | convert ctime(first) | sort first`
5. **Check where else the account logged on.**
   - Splunk: `index=wineventlog EventCode=4624 Account_Name=<user> | stats count by host Source_Network_Address | sort -count`
6. **Ask the host team to review the destination host.**
   - Host: Run Host playbook event 1.1 on the destination host.

CONTAINMENT

- Disable the account and revoke its sessions through the directory administrators.
- Block all traffic from the source address on the core routers.
- Block the source from connecting to any other machine on remote login and file sharing ports (22, 135, 445, 3389, 5985 and 5986).

ESCALATE IF

the account is privileged, the source reached other hosts, or the logon followed a password spray.

EVIDENCE TO RECORD

username, source address, destination host, logon type, first and last times (UTC), search strings, Arkime session tags and exported packet capture.

NOTES

Applies to: user and admin workstations, jump hosts, servers reachable by remote desktop or SSH from other segments, and gateway-terminated remote access.

At risk: Everything the account can reach: mail, file shares and, for a privileged account, the domain controller.

Likely objective: Look like a normal user while mapping the network and looking for higher privileges.

Likely next move: Other hosts that accept the same account, the mail server and file shares, then credential theft or privilege escalation on the first host.

Possible indicators

- A logon from a new address, or from outside the local ranges.
- A burst of 4625 failures followed by a 4624 success from the same address.
- Logons outside the user's normal hours.
- The same account active in two segments at the same time.
- First use of remote desktop or SSH by the account.

1. INITIAL ACCESS · TA0001

1.2 Phishing Email Delivered and Opened

PRIORITY **HIGH** ATT&CK T1566.001 Spearphishing Attachment | T1566.002 Spearphishing Link HOST PLAYBOOK 1.2

Critical if a payload ran or several users opened the message.

TRIGGER

A mail alert, a user report, or a group of messages with the same sender, subject or attachment, followed by new outbound connections from a recipient's host.

RESPONSE STEPS

1 Find every delivery of the message.

- Logs: Mail server logs: sender, recipients, subject, attachment name and size.
- Splunk: `index=mail sender=<sender> | stats count values(recipient) as recipients by subject`
- Arkime: `protocols==smtp && email.src==<sender>` then SPI View on `email.dst`, `email.subject` and `email.fn`.

2 Check each recipient host for new connections after delivery.

- Splunk: `index=net src_ip=<host_ip> NOT dest_ip=<local_range> | stats count min(_time) as first by dest_ip dest_port | convert ctime(first) | sort first`
- Arkime: `ip.src==<host_ip> && ip.dst!=<local_range>` then SPI View on `host.dns`, `host.http` and `tls.ja3`.

3 Check for a link or payload download.

- Arkime: `ip.src==<host_ip> && protocols==http && http.method==GET` then SPI View on `host.http`, `http.uri` and `http.user-agent`.
- Splunk: `index=dns src_ip=<host_ip> | stats count min(_time) as first by query | convert ctime(first) | sort first`

4 Check whether the recipient host then connected to other internal hosts.

- Splunk: `index=net src_ip=<host_ip> dest_ip=<local_range> dest_port IN (135,445,3389,5985,5986,22) | stats count by dest_ip dest_port`

5 Ask the host team to review each recipient who opened the message.

- Host: Run Host playbook event 1.2 on each recipient host.

CONTAINMENT

- Remove the message from all mailboxes and block the sender address, links and attachment hash at the mail server.
- Block the destination addresses and domains the recipient host contacted after opening the message, on the core routers and in name resolution.
- If a payload ran, block all traffic from the host to anywhere off the network, then ask the host team to isolate it. Reset the user's credentials.

ESCALATE IF

a payload ran, command and control traffic was seen, or more than one recipient opened the message.

EVIDENCE TO RECORD

sender, subject, message identifiers, recipient list, attachment name and hash, delivery and first outbound times, destination addresses, search strings.

NOTES

Applies to: the mail server and user and admin workstations in any segment.

At risk: The recipient's account, workstation and mail, and any share they can reach.

Likely objective: A first foothold, and credentials from a trusted user, ideally an administrator or senior staff member.

Likely next move: Command and control from the recipient host (event 10.1), credential theft, and more phishing from the same mailbox.

Possible indicators

- The same attachment hash delivered to many recipients.
- A message from an external sender using an internal display name.
- Recipients connecting to a newly registered domain soon after delivery.
- Attachment types .iso, .img, .lnk, .hta, .js and .zip containing executables.
- A rise in mail volume to administrators and senior staff.

1. INITIAL ACCESS · TA0001

1.3 Exploit of a Public-Facing Application

PRIORITY **CRITICAL** ATT&CK T1190 Exploit Public-Facing Application | T1505.003 Web Shell HOST PLAYBOOK 1.3

Critical if code execution is confirmed; High otherwise.

TRIGGER

An intrusion alert or advisory for a vulnerability exploited in the wild, unusual requests or errors on the web server, or the web server starting connections it does not normally make.

RESPONSE STEPS

1 Review requests to the server around the alert time.

- Logs: Web server access logs and application logs.
- Splunk: `index=web method=POST | stats count by src_ip uri_path status | sort -count`
- Arkime: `ip.dst==<web_server_ip> && http.method==POST` then SPI View on `http.uri`, `ip.src` and `http.user-agent`.

2 Look for exploit patterns in requests.

- Splunk: `index=web ("../" OR "jndi:" OR "cmd=" OR "base64") | stats count by src_ip uri_path`
- Arkime: `ip.dst==<web_server_ip> && http.uri==[*jndi*,*cmd=*,*base64*]`

3 Check what the server connected to after the alert.

- Splunk: `index=net src_ip=<web_server_ip> | stats count min(_time) as first by dest_ip dest_port | convert ctime(first) | sort first`
- Arkime: `ip.src==<web_server_ip> && port.dst!=[53,123]` then SPI View on `ip.dst` and `port.dst`.

4 Check for files delivered to the server over the network.

- Arkime: `ip.dst==<web_server_ip> && (protocols==smb || port.dst==[21,22])` then compare `ip.src` with the approved deployment host.
- Splunk: `index=net dest_ip=<web_server_ip> dest_port IN (21,22,445) NOT src_ip=<deploy_ip> | stats count by src_ip dest_port`

5 Ask the host team to review the server.

- Host: Run Host playbook events 1.3 and 3.5 on the server.

CONTAINMENT

- Allow only secure web traffic (port 443) into the web server. Block everything else into it.
- Block the web server from connecting to any internal machine, except its backend database. Block it from sending traffic off the network, except for software updates.
- Block the attacker addresses on the core routers. Take the site offline if a web shell is confirmed.

ESCALATE IF

code execution is confirmed, a web shell was found, or the server holds credentials that reach the domain controller.

EVIDENCE TO RECORD

application and version, vulnerability reference, attacker addresses, malicious requests, shell paths and hashes, search strings, Arkime session tags.

NOTES

Applies to: web servers, application servers and mail servers reachable from other segments or from off the network through the gateway.

At risk: Application data, database credentials in configuration files, user sessions, and any service account the server uses.

Likely objective: A shell on a server inside the network, credentials, and a place to stage tools or data.

Likely next move: The backend database, the domain controller using stored credentials, and internal hosts through the server (event 3.1).

Possible indicators

- POST requests to new or rarely used paths.
- One source repeatedly requesting the same uncommon file with small, uniform responses.
- The web server connecting to hosts it does not normally reach.
- SMB, FTP or SCP writes into the server from a host other than the deployment host.
- Requests containing ../, jndi: or long base64 strings.

1.4 Unauthorised Device on the Network

PRIORITY **MEDIUM** ATT&CK T1200 Hardware Additions

High if the device reached a sensitive segment or an insider is suspected.

TRIGGER

A new address or hardware address on a segment, an unexpected device in a switch port report, or a user reporting an unknown device in a wall port or plugged into a workstation.

RESPONSE STEPS

1 Identify the device and when it first appeared.

- Logs: DHCP server logs and switch hardware address tables.
- Router: `show arp` on the core router for the segment.
- Arkime: `ip.src==<src_ip>` then SPI View on `ip.dst`, `port.dst` and `protocols`.

2 Check the hardware address vendor and the host name.

- Logs: Hardware address vendor lookup, DHCP lease record and DNS record for the address.

3 Check what the device connected to.

- Splunk:

```
index=net src_ip=<src_ip> | stats count min(_time) as first max(_time) as last by dest_ip dest_port | convert ctime(first) ctime(last)
```

4 Check for scanning from the device.

- Splunk:

```
index=net src_ip=<src_ip> | bin _time span=10m | stats dc(dest_ip) as hosts dc(dest_port) as ports by _time | where hosts>30 OR ports>30
```

5 Find the physical port and the device.

- Logs: Switch hardware address table and port logs. Ask site security or facilities staff to locate the device.
- Host: If the device is a workstation, ask the host team to review it.

CONTAINMENT

- Shut down the switch port.
- Block all traffic from the device's address on the core routers.
- Remove the device and keep it with a record of who held it and when.

ESCALATE IF

the device reached a server or another segment, scanning or interception was seen, or an insider is suspected.

EVIDENCE TO RECORD

hardware address and vendor, switch and port, first and last seen, connections made, host name, location, search strings.

NOTES

Applies to: any network segment, in particular segments in shared or physically open areas.

At risk: A foothold that endpoint tools do not cover, with access to the segment's traffic and hosts.

Likely objective: Long-term access from inside the network, scanning, or capturing traffic.

Likely next move: Scanning (event 7.1), traffic interception (event 6.4) and movement to servers.

Possible indicators

- A hardware address vendor that matches no approved asset.
- A static address outside the DHCP range.
- No host name or an unusual one.
- Activity outside working hours.
- Scanning soon after the device first appeared.

2 TA0002 Execution

Execution happens on hosts, so most evidence is in the Host playbook. The network shows remote execution: one host telling another host to run something. Both events here involve two hosts. Investigate from the network side, then run the Host playbook on both ends.

2. EXECUTION · TA0002

2.1 Remote Execution: WMI and DCOM

PRIORITY **HIGH** ATT&CK T1047 Windows Management Instrumentation | T1021.003 Distributed Component Object Model

HOST PLAYBOOK 2.5

Critical if the target is a server or domain controller.

TRIGGER

An RPC endpoint mapper session (port 135) from one host to another, followed by a high-port RPC session to the same destination, or WmiPrvSE.exe starting processes on the destination.

RESPONSE STEPS

1. **Confirm the RPC sessions.**
   - Logs: Windows Security 4624 (type 3) on the destination. Microsoft-Windows-WMI-Activity/Operational 5857, 5860 and 5861.
   - Splunk: `index=net src_ip=<src_ip> dest_ip=<dst_ip> dest_port=135 | stats count min(_time) as first by dest_ip | convert ctime(first)`
   - Arkime: `ip.src==<src_ip> && ip.dst==<dst_ip> && (port.dst==135 || protocols==dcerpc)` then SPI View on `port.dst`.
2. **Find the account used.**
   - Splunk: `index=wineventlog EventCode=4624 Logon_Type=3 Source_Network_Address=<src_ip> host=<dst_host> | stats count by Account_Name`
3. **Check how many hosts the source targeted.**
   - Splunk: `index=net src_ip=<src_ip> dest_port=135 | bin _time span=10m | stats dc(dest_ip) as targets by _time | where targets>3`
   - Arkime: `ip.src==<src_ip> && port.dst==135` then SPI View on `ip.dst`.
4. **Check what the destination did next.**
   - Splunk: `index=net src_ip=<dst_ip> NOT dest_ip=<local_range> | stats count min(_time) as first by dest_ip dest_port | convert ctime(first) | sort first`
5. **Ask the host team to review both hosts.**
   - Host: Run Host playbook event 2.5 on the source and the destination.

CONTAINMENT

- Block the source from connecting to the destination on remote procedure call ports (135 and 49152 to 65535).
- Block remote procedure calls between workstations as a standing rule.
- Disable the account used. Ask the host team to isolate the destination if commands ran.

ESCALATE IF

a privileged account was used, the destination is a server or domain controller, or several destinations were hit.

EVIDENCE TO RECORD

source and destination hosts, account, times (UTC), ports, search strings, Arkime session tags.

NOTES

Applies to: servers, domain controllers, and user and admin workstations in any segment.

At risk: Commands run on the destination as the account used, with no tool installed on it.

Likely objective: Run commands using built-in Windows features to avoid detection, and move through the network.

Likely next move: Credential theft on the destination, further hosts with the same account (section 8), and persistence.

Possible indicators

- Port 135 followed by a high-port RPC session from a workstation.
- WmiPrvSE.exe starting cmd.exe or powershell.exe.
- One source using RPC to many hosts.
- 4624 type 3 from workstation to workstation.
- WMI-Activity events that name a command line consumer.

2. EXECUTION · TA0002

2.2 Remote Execution: Service Creation (PsExec-Style)

PRIORITY **HIGH** ATT&CK T1569.002 Service Execution | T1021.002 SMB/Windows Admin Shares HOST PLAYBOOK 2.5 8.2

Critical on servers, domain controllers, or with privileged accounts.

TRIGGER

An SMB write to ADMIN$ or access to the svcctl named pipe, followed by a new service on the destination (7045 or 4697) with a random name or an executable in a temporary or system path.

RESPONSE STEPS

1. **Confirm admin share and service control access.**
   - Arkime: `ip.src==<src_ip> && ip.dst==<dst_ip> && smb.share==[*ADMIN$,*IPC$]` then SPI View on `smb.fn`.
   - Splunk:
```
index=wineventlog EventCode=5145 host=<dst_host> Source_Address=<src_ip> | stats count by Account_Name Share_Name Relative_Target_Name
```
2. **Find the new service.**
   - Logs: Windows System 7045 and Security 4697 on the destination.
   - Splunk:
```
index=wineventlog EventCode=7045 host=<dst_host> | table _time Service_Name Service_File_Name
```
3. **Find the file written to the destination.**
   - Arkime: `ip.dst==<dst_ip> && smb.fn==[*.exe,*.dll,*.bat,*.ps1]` then SPI View on `smb.fn` and `ip.src`.
4. **Check for the same service on other hosts.**
   - Splunk:
```
index=wineventlog EventCode=7045 | stats dc(host) as hosts values(Service_File_Name) as files by Service_Name | where hosts>1
```
5. **Ask the host team to review both hosts.**
   - Host: Run Host playbook events 2.5 and 8.2 on the source and the destination.

CONTAINMENT

- Disable the account used and ask the host team to isolate the destination.
- Block file sharing (port 445) from workstations to other workstations as a standing rule.
- Block the source from connecting to the destination on file sharing. Remove the transferred file once it is collected.

ESCALATE IF

a privileged account was used, the destination is a server or domain controller, or the same service appeared on several hosts.

EVIDENCE TO RECORD

source and destination, account, service name and file path, file hash, times (UTC), search strings.

NOTES

Applies to: servers, domain controllers, and user and admin workstations.

At risk: Full control of the destination. The service runs at the highest local privilege level.

Likely objective: Run a payload at the highest local privilege level without an interactive logon, and deploy tools to many hosts.

Likely next move: Credential theft from memory on the destination, further hosts (section 8), and deployment at scale (event 12.2).

Possible indicators

- ADMIN$ and svcctl access from hosts that are not IT admin workstations.
- Services with random names.
- Executables written to C:\Windows or a temporary folder.
- 7045 events with a path in Temp.
- The same service name on many hosts.

3 TA0003 Persistence

The adversary sets up a way back in. Network analysts see this as web shell traffic, changes on network devices, and new accounts or group changes recorded on the domain controller. Host persistence such as scheduled tasks, run keys and services is in the Host playbook.

3. PERSISTENCE · TA0003

3.1 Web Shell on a Web Server

PRIORITY **CRITICAL** ATT&CK T1505.003 Web Shell HOST PLAYBOOK 3.5

Critical if the server is reachable from other segments or holds credentials.

TRIGGER

A rarely requested script file receiving POST requests with small, uniform responses, a new script in the web root, or the web server making connections it does not normally make.

RESPONSE STEPS

1. **Find rare POST targets.**
   - Splunk: `index=web method=POST | stats count dc(src_ip) as sources by uri_path | where sources<3 | sort -count`
   - Arkime: `ip.dst==<web_server_ip> && http.method==POST` then SPI View on `http.uri`.
2. **Find paths first seen recently.**
   - Splunk: `index=web earliest=-30d | stats min(_time) as first count by uri_path | where first>relative_time(now(),"-7d") | sort -count`
3. **Find who is using the suspected shell.**
   - Splunk: `index=web uri_path=<shell_path> | stats count sum(bytes) as bytes by src_ip`
   - Arkime: `ip.dst==<web_server_ip> && http.uri==*<shell_path>*` then SPI View on `ip.src` and `http.user-agent`.
4. **Check whether the shell is reached from inside the network.**
   - Arkime: `ip.dst==<web_server_ip> && ip.src==<local_range> && http.uri==*<shell_path>*`
5. **Check what the server connected to after each request.**
   - Splunk: `index=net src_ip=<web_server_ip> dest_ip=<local_range> NOT dest_port IN (53,123) | stats count by dest_ip dest_port`
6. **Ask the host team to find and preserve the file.**
   - Host: Run Host playbook event 3.5 on the server.

CONTAINMENT

- Block the source addresses of the shell requests on the core routers.
- Block the web server from connecting to any internal machine, except its backend database.
- Take the site offline or into maintenance mode until the file is removed and the application is checked. Rotate every credential stored on the server.

ESCALATE IF

always. Treat the server as compromised and check where it connected next.

EVIDENCE TO RECORD

shell path and hash, source addresses, request times (UTC), connections made by the server, search strings.

NOTES

Applies to: web servers and application servers.

At risk: Control of the server, its stored credentials, and a trusted address inside the network.

Likely objective: Durable access that survives cleanup of other hosts, a place to host tools and a way to stage data.

Likely next move: The backend database, the domain controller using stored credentials, and users who download files from the server.

Possible indicators

- POST requests to a script file that did not exist last week.
- One source requesting the same file at regular intervals.
- Responses of the same small size.
- Internal hosts requesting the shell path.
- The server starting connections to the domain controller or file server.

3. PERSISTENCE · TA0003

3.2 Persistence on a Core Router

PRIORITY **CRITICAL** ATT&CK T1136.001 Local Account | T1098.004 SSH Authorized Keys | T1053.003 Cron | T1037 Boot or Logon Initialization Scripts

Always critical. A core router carries traffic for every segment.

TRIGGER

A configuration commit outside a change window, a login from an unexpected source, or a new user, SSH key, scheduled task or script on a core router.

RESPONSE STEPS

1. **Review recent commits.**
   - Router: `show system commit` then, in configuration mode, `compare <n>` against the last trusted commit.
   - Splunk: `index=network_devices commit | table _time host _raw`
2. **Check users, keys and scheduled tasks.**
   - Router: `show configuration commands | match "system login"` · `show configuration commands | match "task-scheduler"`
   - Router: `cat /home/*/.ssh/authorized_keys` · `ls -la /config/scripts/` · `sudo crontab -l`
3. **Check logins.**
   - Splunk: `index=network_devices sshd "Accepted" | rex "Accepted \S+ for (?<user>\S+) from (?<src>\S+)" | stats count by host user src`
   - Arkime: `ip.dst==<core_router_ip> && port.dst==22 && ip.src!=<mgmt_range>`
4. **Check for the default account.**
   - Router: `show configuration commands | match "user vyatta"`
   - Splunk: `index=network_devices sshd vyatta | stats count by host`
5. **Check listening ports and processes on the router shell.**
   - Router: `sudo ss -tulpn` · `ps aux`
6. **Copy the evidence before changing anything.**
   - Router: Copy `/config/config.boot` and the commit history off the router to the evidence host.

CONTAINMENT

- Allow only one trusted management workstation to log in to the core routers. Block all other login and management traffic to them, including Telnet.
- Block the core routers from starting connections to anything except the logging, time, authentication and software update servers.
- After the evidence is copied, remove the unauthorised users, keys, tasks and scripts. Rotate all passwords, SSH keys, SNMP communities and shared keys. If the router cannot be trusted, reinstall from a known-good image and restore a known-good configuration. Review `/config/scripts/` before restoring it.

ESCALATE IF

always. Core router changes need the incident lead before any containment that could cut segments off.

EVIDENCE TO RECORD

commit history and differences, users and keys found, login sources and times (UTC), copy of the configuration with hash, search strings.

NOTES

Applies to: core routers.

At risk: Routing and the rules between segments, plus a configuration file holding password hashes, SNMP communities and shared keys.

Likely objective: Access that survives host rebuilds, and control of routing and rules between segments.

Likely next move: Changing rules to open paths (event 5.2), tunnels or packet capture (event 13.2).

Possible indicators

- A commit outside a change window.
- A new user, SSH key or scheduled task.
- A file in `/config/scripts/` that is not in the baseline.
- A login as the default vyatta account.
- A new listening port or an unfamiliar process on the router.

3.3 New Accounts or Privileged Group Changes

PRIORITY **HIGH** ATT&CK T1136.002 Domain Account | T1098 Account Manipulation HOST PLAYBOOK 4.6 | 3.6

Critical for domain administrator, enterprise administrator or service accounts.

TRIGGER

Windows events 4720 (account created), 4728, 4732 or 4756 (added to a privileged group) or 4738 (account changed) on a domain controller, outside a change record or from a non-admin source.

RESPONSE STEPS

1. **List account and group changes.**
   - Logs: Windows Security 4720, 4722, 4728, 4732, 4738 and 4756 on the domain controller.
   - Splunk: `index=wineventlog EventCode IN (4720,4722,4728,4732,4738,4756) | stats count by EventCode src_user user`
2. **Identify where the change came from.**
   - Splunk: `index=wineventlog EventCode=4624 Account_Name=<account> | stats count by Source_Network_Address Logon_Type host`
3. **Check management access to the domain controller.**
   - Arkime: `ip.dst==<dc_ip> && port.dst==[22,3389,5985,5986] && ip.src!=<mgmt_range>`
   - Splunk: `index=net dest_ip=<dc_ip> dest_port IN (22,3389,5985,5986) NOT src_ip=<mgmt_range> | stats count by src_ip dest_port`
4. **Check activity by the new or changed account.**
   - Splunk: `index=wineventlog EventCode=4624 Account_Name=<new_account> | stats count min(_time) as first by Source_Network_Address host | convert ctime(first)`
5. **Ask the host team to review the hosts involved.**
   - Host: Run Host playbook event 4.6 on the host that made the change and event 3.6 on hosts the new account logged on to.

CONTAINMENT

- Ask the directory administrators to disable the new or changed account and remove it from privileged groups.
- Allow only one trusted management workstation to connect to the domain controller on remote login ports (22, 3389, 5985 and 5986). Block everyone else.
- Block the domain controller from sending traffic off the network, except to its approved name resolution and time servers. Ask the host team to isolate the host that made the change.

ESCALATE IF

a privileged group was changed, the change came from a non-admin source, or several accounts were changed.

EVIDENCE TO RECORD

account names, groups, change times (UTC), source host and account, search strings.

NOTES

Applies to: domain controllers.

At risk: Control of the domain, and persistent access through an account that looks legitimate.

Likely objective: Access that survives a reset of the original credentials, with enough privilege to act freely.

Likely next move: Use of the new account from another host (events 4.1 and 8.5), and Group Policy changes (event 4.2).

Possible indicators

- Accounts created outside working hours.
- Names that imitate service or admin accounts.
- Accounts added to Domain Admins, Administrators or Remote Desktop Users.
- 4720 followed by 4728 within minutes.
- Changes made from a workstation.

4 TA0004 Privilege Escalation

The adversary raises their access, usually by using a privileged account or changing policy that applies to many hosts. Local privilege escalation on a single host is in the Host playbook. The network shows where privileged credentials are used and what policy changes.

4. PRIVILEGE ESCALATION · TA0004

4.1 Privileged Account: Unexpected Source

PRIORITY **CRITICAL** ATT&CK T1078.002 Domain Accounts | T1021 Remote Services HOST PLAYBOOK 4.7

Always critical for domain or enterprise administrator accounts.

TRIGGER

A privileged account logs on (4624 type 3, 9 or 10, with 4672) from a host outside the IT admin workstation range, or to a host it does not normally administer.

RESPONSE STEPS

1. **List privileged logons from outside the management range.**
   - Logs: Windows Security 4624, 4672 and 4648 on the destination and the domain controller.
   - Splunk:
```
index=wineventlog EventCode=4624 Logon_Type IN (3,9,10) Account_Name IN (<admin_accounts>) NOT Source_Network_Address=<mgmt_range> | stats count by Account_Name Source_Network_Address host
```
2. **Check where the account was given special privileges.**
   - Splunk:
```
index=wineventlog EventCode=4672 Account_Name IN (<admin_accounts>) | stats count by host Account_Name | sort -count
```
3. **Check for explicit credential use.**
   - Splunk:
```
index=wineventlog EventCode=4648 | stats count by Account_Name Target_Server_Name
```
4. **Trace the source host.**
   - Arkime: `ip.src==<src_ip> && ip.dst==<local_range>` then open Connections and SPI View on `ip.dst` and `port.dst`.
   - Splunk:
```
index=net src_ip=<src_ip> | stats count min(_time) as first by dest_ip dest_port | convert ctime(first) | sort first
```
5. **Ask the host team to review the source and destination hosts.**
   - Host: Run Host playbook event 4.7 on both hosts.

CONTAINMENT

- Block the source host from connecting to servers, the domain controller and the core routers on remote login and file sharing ports.
- Allow only one trusted management workstation to manage servers. Block all other hosts from doing so.
- Ask the directory administrators to reset the account, but only after the access path is closed. A reset earlier lets the adversary capture the new password.

ESCALATE IF

always. A privileged account used from an unexpected source means the adversary may hold domain-level access.

EVIDENCE TO RECORD

account, source and destination hosts, logon types, times (UTC), search strings, Arkime session tags.

NOTES

Applies to: servers, domain controllers, admin workstations, jump hosts.

At risk: Control of every host the account can reach, including the domain controller.

Likely objective: Reach the domain controller and deploy to many hosts at once.

Likely next move: The domain controller (events 6.3, 3.3 and 4.2), file servers, and core routers.

Possible indicators

- An admin account logging on from a user workstation or another segment.
- First-time administrator logon to a host.
- 4672 on hosts the account does not normally administer.
- 4648 events from workstations.
- The same admin account active in two segments.

4. PRIVILEGE ESCALATION · TA0004

4.2 Group Policy or Domain Policy Modified

PRIORITY **CRITICAL** ATT&CK T1484.001 Group Policy Modification

Always critical. Group Policy runs code on every machine in its scope.

TRIGGER

Event 5136 (directory object modified, groupPolicyContainer), new or changed files in SYSVOL, or Group Policy changes outside a change record.

RESPONSE STEPS

1. **List policy changes.**

   Logs: Windows Security 5136 and 5145 on the domain controller.

   Splunk:
   ```
   index=wineventlog EventCode=5136 ObjectClass=groupPolicyContainer | stats count values(ObjectDN) as policies by src_user
   ```

2. **Check for changed files in SYSVOL.**

   Arkime:
   ```
   ip.dst==<dc_ip> && smb.share==*SYSVOL && smb.fn==[*.ps1,*.bat,*.vbs,*.exe]
   ```

   Splunk:
   ```
   index=wineventlog EventCode=5145 Share_Name="*SYSVOL*" | stats count by Source_Address Account_Name Relative_Target_Name
   ```

3. **Identify the source of the change.**

   Arkime:
   ```
   ip.dst==<dc_ip> && port.dst==[135,445,3389,5985] && ip.src!=<mgmt_range>
   ```

   Splunk:
   ```
   index=wineventlog EventCode=4624 Account_Name=<account> | stats count by Source_Network_Address host
   ```

4. **Check for activity that follows policy refresh.**

   Splunk:
   ```
   index=net NOT dest_ip=<local_range> | bin _time span=5m | stats dc(src_ip) as sources by dest_ip _time | where sources>10
   ```

5. **Ask the directory administrators to compare the policy against the last known-good backup.**

   Host: Ask the directory administrators for the policy export and backup comparison.

CONTAINMENT

- Allow only one trusted management workstation to connect to the domain controller on remote login ports. Block everyone else.
- Block the domain controller from starting connections to workstations on remote login and file sharing ports. It should never push to workstations.
- Disable the account that made the change and ask the host team to isolate the source host. Ask the directory administrators to revert the policy.

ESCALATE IF

always. A policy change with code in it can reach every host within the next policy refresh.

EVIDENCE TO RECORD

policy names and identifiers, changed files and hashes, account, source host, times (UTC), search strings.

NOTES

Applies to: domain controllers.

At risk: Code execution on every host and user in the policy scope, across segments.

Likely objective: Deploy a payload or change security settings on every machine at once.

Likely next move: Mass deployment such as ransomware (event 12.2), and disabling security tools (event 5.1).

Possible indicators

- A new or changed script in SYSVOL.
- Policy changes outside a change record.
- Policy changes made by an account that does not manage policy.
- Many hosts contacting one new destination at the same time.
- Management access to the domain controller from outside the management range.

5 TA0005 Defense Evasion

The adversary reduces what defenders can see or changes the network to hide movement. Network analysts see gaps in logs and sensor data, changes to rules and routes, and traffic that does not match its protocol. Host-level evasion is in the Host playbook.

5. DEFENSE EVASION · TA0005

5.1 Logging or Sensor Tampering

PRIORITY **HIGH** ATT&CK T1562.001 Disable or Modify Tools | T1562.002 Disable Windows Event Logging | T1070 Indicator Removal

HOST PLAYBOOK 5.1 5.2

Critical if a core router or a domain controller stopped logging.

TRIGGER

A device stops sending logs, a drop in traffic seen by an Arkime sensor with no matching drop on the router interface, event 1102 (audit log cleared) or 4719 (audit policy changed), or the logging configuration changed on a router.

RESPONSE STEPS

1. **Find devices that stopped logging.**
   - Splunk: `| tstats latest(_time) as last where index=network_devices OR index=wineventlog by host | eval mins_silent=round((now()-last)/60) | where mins_silent>15`
2. **Check for cleared logs and audit policy changes.**
   - Logs: Windows Security 1102 and 4719, Windows System 104.
   - Splunk: `index=wineventlog EventCode IN (1102,104,4719) | table _time host EventCode`
3. **Compare sensor volume with router interface counters.**
   - Router: `show interfaces ethernet <port>` and compare packet counts with the same period yesterday.
   - Arkime: Open Stats and Capture Nodes. Compare packets per second against the same time yesterday.
4. **Check for logging configuration changes on routers.**
   - Router: `show configuration commands | match "system syslog"`
   - Splunk: `index=network_devices commit | table _time host _raw`
5. **Identify who made the change.**
   - Splunk: `index=network_devices sshd "Accepted" | rex "Accepted \S+ for (?<user>\S+) from (?<src>\S+)" | stats count by host user src`
6. **Ask the host team to review affected hosts.**
   - Host: Run Host playbook events 5.1 and 5.2 on the affected hosts.

CONTAINMENT

- Allow only one trusted management workstation to change device configuration. Block all other management traffic to the core routers.
- Restore logging from the last known-good configuration. Treat the gap as unmonitored and review it using other sources such as firewall counters and host logs.
- Block the source of the change from all management access and ask the host team to isolate the host it came from.

ESCALATE IF

a core router or a domain controller stopped logging, or the gap matches other events in this playbook.

EVIDENCE TO RECORD

devices and gap start and end times (UTC), the change made, source and account, counters compared, search strings.

NOTES

Applies to: core routers, domain controllers, Arkime sensors, any logging host.

At risk: Visibility. Everything that happened during the gap is harder to prove.

Likely objective: Hide the activity that follows or has just happened.

Likely next move: Exfiltration or destructive action during the gap, and rule changes (event 5.2).

Possible indicators

- A device silent for more than 15 minutes.
- Events 1102, 104 or 4719.
- Sensor traffic falling with no matching drop in router counters.
- Router syslog settings removed or pointed elsewhere.
- A gap that starts just before another alert.

5.2 Firewall, Access Control or Routing Change

PRIORITY **CRITICAL** ATT&CK T1562.004 Disable or Modify System Firewall | T1599 Network Boundary Bridging

Critical if a rule separating segments was removed or a route bypasses a security control.

TRIGGER

A configuration commit on a core router outside a change window, a previously blocked connection between segments now succeeding, or traffic taking a new path.

RESPONSE STEPS

1. **List recent commits and compare them with the last trusted commit.**
   - Router: `show system commit` then, in configuration mode, `compare <n>`.
   - Splunk: `index=network_devices commit | table _time host _raw`
2. **Look for newly permitted flows between segments.**
   - Splunk: `index=net src_ip=<segment_range> dest_ip=<other_segment_range> | stats count values(dest_port) as ports min(_time) as first by src_ip dest_ip | convert ctime(first)`
   - Arkime: `ip.src==<segment_range> && ip.dst==<other_segment_range>` then SPI View on `port.dst`.
3. **Look for new routes, address translation and rules.**
   - Router: `show configuration commands | match "protocols static"` · `show configuration commands | match "nat"` · `show configuration commands | match "firewall"`
4. **Check for new traffic leaving the network after the change.**
   - Arkime: `ip.src==<local_range> && ip.dst!=<local_range>`
5. **Identify who made the change.**
   - Splunk: `index=network_devices sshd "Accepted" | rex "Accepted \S+ for (?<user>\S+) from (?<src>\S+)" | stats count by host user src`

CONTAINMENT

- With the incident lead's approval, revert to the last trusted commit. Copy the current configuration first.
- Block the newly permitted flow between the segments on the core routers.
- Allow only one trusted management workstation to log in to the core routers. Block all other login and management traffic to them.

ESCALATE IF

always. A rule change on a core router can remove the separation between segments.

EVIDENCE TO RECORD

commit history and differences, rules and routes changed, login source and account, times (UTC), copy of the configuration with hash, search strings.

NOTES

Applies to: core routers.

At risk: The separation between segments and the protection of sensitive segments.

Likely objective: Open a path to a sensitive segment or out of the network, and hide movement.

Likely next move: Movement between segments (event 8.6) and exfiltration (section 11).

Possible indicators

- A commit outside a change window.
- A rule or route that is not in the baseline.
- A blocked connection between segments that now succeeds.
- A new address translation rule that exposes an internal host.
- A new default or static route.

5. DEFENSE EVASION · TA0005

5.3 Traffic on Non-Standard Ports or Mismatched Protocols

PRIORITY **MEDIUM** ATT&CK T1571 Non-Standard Port | T1001.003 Protocol Impersonation HOST PLAYBOOK 10.1

High if the destination is off the network and the source is a server or a host in a sensitive segment.

TRIGGER

Arkime shows a protocol on a port that does not normally carry it (TLS, SSH or HTTP on an unusual port), or a common port carrying a different protocol, such as SSH on port 443.

RESPONSE STEPS

1. **Find common protocols on unusual ports.**
   - Arkime `protocols==tls && port.dst!=[443,636,993,995,465,8443]` then SPI View on `port.dst` and `ip.dst`.
   - Arkime `protocols==ssh && port.dst!=22` · `protocols==http && port.dst!=[80,8080]`
2. **Find other protocols on common ports.**
   - Arkime `port.dst==443 && protocols!=tls` then SPI View on `protocols`, `ip.src` and `ip.dst`.
3. **Check destination and ports used by the host.**
   - Splunk `index=net src_ip=<host_ip> NOT dest_ip=<local_range> NOT dest_port IN (53,80,123,443) | stats count sum(bytes_out) as bytes by dest_ip dest_port | sort -bytes`
4. **Check whether the connections repeat at regular intervals.**
   - Splunk `index=net src_ip=<host_ip> dest_ip=<dst_ip> | sort 0 _time | streamstats current=f last(_time) as prev | eval gap=_time-prev | stats count avg(gap) as avg stdev(gap) as sd | where count>20 AND sd<avg*0.2`
5. **Ask the host team to review the source host.**
   - Host Run Host playbook event 10.1 on the source host.

CONTAINMENT

- Allow outbound traffic from the segment only on approved ports. Block all other ports off the network.
- Block the destination address on the core routers.
- If the source is a server, block all its traffic off the network and ask the host team to isolate it.

ESCALATE IF

the source is a server or domain controller, the destination is new, or the traffic repeats at regular intervals.

EVIDENCE TO RECORD

source and destination, ports and protocols observed, times (UTC), session sizes, search strings, Arkime session tags.

NOTES

Applies to: any host with off-network access.

At risk: A channel that port-based rules and simple monitoring do not catch.

Likely objective: Blend into allowed traffic or pass through filters that only check ports.

Likely next move: Command and control (section 10) and exfiltration (section 11).

Possible indicators

- TLS or SSH on a port other than the usual one.
- Non-TLS traffic on port 443.
- A rarely used port with regular, small sessions.
- A destination with no host name.
- A source that has not used the port before.

6 TA0006 Credential Access

The adversary steals or guesses credentials. The network shows guessing attempts, requests for tickets and credential data, and interception of traffic. Credential theft from host memory is in the Host playbook.

6. CREDENTIAL ACCESS · TA0006

6.1 Brute Force and Password Spraying

PRIORITY **HIGH** ATT&CK T1110.001 Password Guessing | T1110.003 Password Spraying HOST PLAYBOOK 6.4

Critical if a success follows the failures or privileged accounts are targeted.

TRIGGER

Many failed logons (4625), Kerberos pre-authentication failures (4771 with failure code 0x18) or NTLM failures (4776) from one source across many accounts, or many failed SSH or remote desktop attempts from one source.

RESPONSE STEPS

1. **Count failures by source.**

   Logs: Windows Security 4625, 4771 and 4776 on the domain controller. Router sshd logs.

   Splunk:
   ```
   index=wineventlog EventCode=4625 | stats count dc(Account_Name) as accounts by Source_Network_Address | where count>20 | sort -count
   ```

2. **Check for Kerberos pre-authentication failures.**

   Splunk:
   ```
   index=wineventlog EventCode=4771 Failure_Code=0x18 | stats count dc(Account_Name) as accounts by Client_Address | sort -accounts
   ```

3. **Check for a success after the failures.**

   Splunk:
   ```
   index=wineventlog (EventCode=4625 OR EventCode=4624) Source_Network_Address=<src_ip> | sort 0 _time | table _time EventCode Account_Name Logon_Type host
   ```

4. **Check attempts on SSH, remote desktop and web logons.**

   Arkime: `ip.src==<src_ip> && port.dst==[22,3389,445,5985,443]` then SPI View on `ip.dst` and `port.dst`.

   Splunk:
   ```
   index=net src_ip=<src_ip> dest_port IN (22,3389,445,5985) | stats count by dest_ip dest_port | sort -count
   ```

5. **Check for guessing against the core routers.**

   Splunk:
   ```
   index=network_devices sshd ("Failed password" OR "Invalid user") | stats count by host
   ```

6. **Ask the host team to review targeted hosts.**

   Host: Run Host playbook event 6.4 on hosts that received successful logons.

CONTAINMENT

- Block all traffic from the source address on the core routers.
- Block the source from connecting to any other machine on remote login and file sharing ports.
- Ask the directory administrators to lock or reset accounts that were guessed correctly.

ESCALATE IF

a guess succeeded, privileged accounts were targeted, or the source is inside the network.

EVIDENCE TO RECORD

source address, accounts targeted, failure and success counts and times (UTC), search strings.

NOTES

Applies to: domain controllers, servers with SSH or remote desktop, core routers, any logon service.

At risk: Accounts with weak passwords, and the data and hosts those accounts reach.

Likely objective: Obtain valid credentials without malware.

Likely next move: Logon with the guessed account (event 1.1), then discovery and movement.

Possible indicators

- Many 4625 events from one address.
- One password tried against many accounts.
- Failures across many hosts in a short period.
- A 4624 success from the same address after failures.
- Failures against accounts that do not exist.

6.2 Kerberoasting and AS-REP Roasting

PRIORITY **HIGH** ATT&CK T1558.003 Kerberoasting | T1558.004 AS-REP Roasting HOST PLAYBOOK 6.5

Critical if the requested accounts are privileged service accounts.

TRIGGER

A workstation requests Kerberos service tickets (4769) for many different services in a short period, tickets using the weaker RC4 encryption (type 0x17), or authentication requests (4768) with no pre-authentication.

RESPONSE STEPS

1. **List ticket requests by client.**
   Splunk `index=wineventlog EventCode=4769 Ticket_Encryption_Type=0x17 | stats dc(Service_Name) as services by Client_Address | where services>5 | sort -services`
2. **List the accounts targeted.**
   Splunk `index=wineventlog EventCode=4769 Ticket_Encryption_Type=0x17 Client_Address=<src_ip> | stats count by Service_Name`
3. **Check requests without pre-authentication.**
   Splunk `index=wineventlog EventCode=4768 Pre_Authentication_Type=0 | stats count by Account_Name Client_Address`
4. **Check the Kerberos sessions on the network.**
   Arkime `ip.src==<src_ip> && ip.dst==<dc_ip> && protocols==krb5` then SPI View on `krb5.sname`. Dozens of service names indicates roasting.
5. **Check whether a targeted account then logged on from a new source.**
   Splunk `index=wineventlog EventCode=4624 Account_Name=<service_account> | stats count min(_time) as first by Source_Network_Address host | convert ctime(first)`
6. **Ask the host team to review the source host.**
   Host Run Host playbook event 6.5 on the source host.

CONTAINMENT

- Block the source host from connecting to anything except the services it needs.
- Ask the directory administrators to reset the targeted service account passwords to long random values, after the source is contained.
- Recommend disabling RC4 ticket encryption where the environment allows it.

ESCALATE IF

a privileged service account was targeted, or the account logged on from a new source after the requests.

EVIDENCE TO RECORD

source host, accounts targeted, ticket counts and times (UTC), account activity after the requests, search strings.

NOTES

Applies to: user and admin workstations, domain controllers.

At risk: Password hashes for service accounts, which can be cracked offline. Service accounts are often privileged.

Likely objective: Obtain service account passwords without touching the systems those accounts run on.

Likely next move: Logon as the service account to its hosts (events 4.1 and 8.5) and then the domain controller.

Possible indicators

- Many 4769 events with type 0x17 from one client.
- Requests for services the client has never used.
- 4768 with pre-authentication type 0.
- A service account logging on from a workstation.
- Ticket requests at high speed.

6.3 Domain Credential Theft: DCSync and AD Database Copy

PRIORITY **CRITICAL** ATT&CK T1003.006 DCSync | T1003.003 NTDS HOST PLAYBOOK 6.2

Always critical. This gives the adversary every credential in the domain.

TRIGGER

Directory replication requested by a host that is not a domain controller (event 4662 with replication rights), a large SMB transfer from a domain controller, or a copy of ntds.dit or the SYSTEM registry hive.

RESPONSE STEPS

1 Check for replication requests.

Logs — Windows Security 4662 on the domain controller.

Splunk
```
index=wineventlog EventCode=4662 (Properties="*1131f6aa-9c07-11d1-f79f-00c04fc2dcd2*" OR Properties="*1131f6ad-9c07-11d1-f79f-00c04fc2dcd2*") NOT Account_Name="*$" | stats count by Account_Name
```

2 Find the host that sent the replication request.

Arkime `ip.dst==<dc_ip> && protocols==dcerpc && ip.src!=<other_dc_ips>` then SPI View on `ip.src`.

Splunk
```
index=net dest_ip=<dc_ip> dest_port>=49152 | stats count by src_ip | sort -count
```

3 Check for a copy of the AD database over SMB.

Arkime `ip==<dc_ip> && smb.fn==[*ntds*,*SYSTEM*,*.dit]`

Splunk
```
index=net src_ip=<dc_ip> dest_port=445 | stats sum(bytes) as bytes by dest_ip | eval MB=round(bytes/1048576,1) | sort -MB
```

4 Identify the account used.

Splunk
```
index=wineventlog EventCode=4624 Source_Network_Address=<src_ip> | stats count by Account_Name Logon_Type
```

5 Check management access to the domain controller.

Arkime `ip.dst==<dc_ip> && port.dst==[22,3389,5985,5986] && ip.src!=<mgmt_range>`

6 Ask the host team to review the source host.

Host — Run Host playbook event 6.2 on the source host and the domain controller.

CONTAINMENT

- Ask the host team to isolate the host that made the replication request.
- Allow only one trusted management workstation to connect to the domain controller on remote login ports. Block everyone else.
- Do not take the only domain controller offline without a plan. Authentication for every segment depends on it.

ESCALATE IF

always. Assume every domain credential is compromised, including the krbtgt account. Recovery needs a double krbtgt reset and a reset of all privileged accounts, done after the access path is closed.

EVIDENCE TO RECORD

source host and account, replication or copy times (UTC), volume transferred, files copied, search strings, Arkime session tags.

NOTES

Applies to: domain controllers.

At risk: Every credential in the domain, including the ability to forge Kerberos tickets.

Likely objective: Full control of the domain and persistence that survives password resets.

Likely next move: Use of any account anywhere (section 8), forged tickets, and deployment through Group Policy (event 12.2).

Possible indicators

- Replication requests from a host that is not a domain controller.
- 4662 with replication rights from a user account.
- Large SMB transfers out of a domain controller.
- Files named ntds.dit or SYSTEM copied over the network.
- Management access to the domain controller from outside the management range.

6.4 Credential Interception on the Network

PRIORITY **HIGH** ATT&CK T1557.001 LLMNR/NBT-NS Poisoning and SMB Relay | T1557.002 ARP Cache Poisoning | T1557.003 DHCP Spoofing

Critical if a domain controller, file server or admin workstation is the victim.

TRIGGER

Name resolution replies (LLMNR on port 5355, NBT-NS on port 137) from a host that is not a DNS server, DHCP offers from an unapproved host, a hardware address change for the gateway, or many SMB authentications to one workstation.

RESPONSE STEPS

1. **Find name resolution replies from unexpected hosts.**
   - Arkime: `port.src==[5355,137]` then SPI View on `ip.src` and `ip.dst`.
2. **Find DHCP offers from unapproved hosts.**
   - Arkime: `port.src==67 && ip.src!=<dhcp_server_ip>`
3. **Check for authentication attempts against the suspected host.**
   - Arkime: `ip.dst==<host_ip> && protocols==smb` then SPI View on `ip.src` and `smb.user`.
   - Splunk: `index=net dest_ip=<host_ip> dest_port IN (445,80) | stats dc(src_ip) as sources count by dest_ip`
4. **Check for hardware address changes.**
   - Router: `show arp` then compare the hardware address for the default gateway and key servers with the baseline.
   - Logs: Switch logs for duplicate address and port security events.
5. **Find the suspected host.**
   - Logs: Switch hardware address table for the port. Ask the host team to review the host.

CONTAINMENT

- Shut down the switch port of the interception host and block all its traffic on the core routers.
- Ask the directory administrators to reset accounts that authenticated to the interception host.
- Recommend turning off LLMNR and NBT-NS by policy, and allowing DHCP replies on the switch only from the approved DHCP server port.

ESCALATE IF

a privileged account authenticated to the interception host, or the host relayed to a server.

EVIDENCE TO RECORD

suspected host and address, hardware address, switch port, accounts seen, times (UTC), search strings, Arkime session tags.

NOTES

Applies to: user networks in any segment, with higher risk where users share a segment with servers.

At risk: Password hashes of anyone on the segment, and the ability to relay a logon to a server.

Likely objective: Capture credentials that hosts send automatically, relay them to reach servers, or redirect traffic.

Likely next move: Use of captured credentials (events 4.1 and 8.5) and relay to the file server or domain controller.

Possible indicators

- LLMNR or NBT-NS replies from a workstation.
- A DHCP offer from an address that is not the DHCP server.
- A new hardware address for the default gateway.
- Many hosts authenticating to one workstation over SMB.
- Duplicate address messages in switch logs.

7 TA0007 Discovery

The adversary maps the network and the domain. Discovery produces bursts of connections and queries that stand out against the baseline. Look at volume and spread, then find the host doing it.

7. DISCOVERY · TA0007

7.1 Network Scanning and Remote System Discovery

PRIORITY **MEDIUM** ATT&CK T1046 Network Service Discovery | T1018 Remote System Discovery HOST PLAYBOOK 7.3

High from a server, from a host in a sensitive segment, or when several hosts scan.

TRIGGER

One host connecting to many destinations or ports in a short period, many sessions with little or no reply, or connections to addresses that do not exist.

RESPONSE STEPS

1. **Confirm the scan pattern.**
   - Splunk `index=net src_ip=<host_ip> | bin _time span=10m | stats dc(dest_ip) as hosts dc(dest_port) as ports by _time | where hosts>30 OR ports>30`
   - Arkime `ip.src==<host_ip>` then SPI View on `ip.dst` and `port.dst`. A long list of destinations with one session each is a scan.
2. **Find the ports probed.**
   - Splunk `index=net src_ip=<host_ip> | stats dc(dest_ip) as hosts by dest_port | sort -hosts`
   - Logs Common targets are 22, 135, 139, 445, 1433, 3389, 5985 and 5986.
3. **Check which segments were scanned.**
   - Arkime `ip.src==<host_ip> && ip.dst==<local_range>` then group the destinations by segment range.
4. **Find destinations that were contacted again after the scan.**
   - Splunk `index=net src_ip=<host_ip> | stats count by dest_ip dest_port | where count>5 | sort -count`
5. **Ask the host team to review the source host.**
   - Host Run Host playbook event 7.3 on the source host.

CONTAINMENT

- Block the scanning host from connecting to other segments.
- Block the scanning host from connecting to any other machine on remote login and file sharing ports.
- Ask the host team to isolate the host if it is a server or if the scan is still running.

ESCALATE IF

the source is a server or in a sensitive segment, several hosts are scanning, or the scan is followed by connections to the hosts that replied.

EVIDENCE TO RECORD

source host, time range (UTC), ports and ranges scanned, destinations contacted again, search strings, Arkime session tags.

NOTES

Applies to: any host.

At risk: Nothing is taken, but the adversary learns which hosts and services exist.

Likely objective: Choose targets such as servers, file shares, the domain controller and admin hosts.

Likely next move: Movement to the hosts found (section 8), and exploitation of a service found.

Possible indicators

- One host reaching more than 30 destinations in 10 minutes.
- Many sessions with fewer than 10 packets.
- Connections to unused addresses.
- A host scanning a range it has never contacted.
- The same port probed on many hosts.

7. DISCOVERY · TA0007

7.2 Active Directory and Domain Enumeration

PRIORITY **MEDIUM** ATT&CK T1087.002 Domain Account | T1069.002 Domain Groups | T1482 Domain Trust Discovery

HOST PLAYBOOK 7.2

High if the source is a server or the volume matches known collection tools.

TRIGGER

A burst of directory queries (LDAP on ports 389, 636 and 3268, or SAMR over RPC) from one host, well above baseline, or many Kerberos requests for different services.

RESPONSE STEPS

1. **Compare directory query volume with a normal workstation.**
   - Splunk: `index=net dest_ip=<dc_ip> dest_port IN (389,636,3268,3269) | stats count by src_ip | sort -count`
   - Arkime: `ip.src==<host_ip> && ip.dst==<dc_ip> && port.dst==[389,636,3268]` then compare the session count with a normal workstation.
2. **Check for named pipe enumeration over SMB.**
   - Arkime: `ip.src==<host_ip> && ip.dst==<dc_ip> && smb.fn==[*samr*,*lsarpc*,*srvsvc*]`
   - Splunk: `index=wineventlog EventCode=5145 Relative_Target_Name IN (samr,lsarpc,srvsvc) | stats count by Source_Address Account_Name | sort -count`
3. **Check for group membership enumeration on hosts.**
   - Logs: Windows Security 4798 and 4799.
   - Splunk: `index=wineventlog EventCode IN (4798,4799) | stats count by Account_Name host | sort -count`
4. **Identify the account used.**
   - Splunk: `index=wineventlog EventCode=4624 Source_Network_Address=<host_ip> | stats count by Account_Name Logon_Type host`
5. **Ask the host team to review the source host.**
   - Host: Run Host playbook event 7.2 on the source host.

CONTAINMENT

- Block the source host from connecting to the domain controller, except for logon and name resolution.
- Block the source host from connecting to other segments.
- Ask the directory administrators to reset the account used if it is not the host's normal user.

ESCALATE IF

the source is a server or admin workstation, the account is privileged, or the queries are followed by connections to admin hosts.

EVIDENCE TO RECORD

source host, account, query counts against baseline, times (UTC), search strings, Arkime session tags.

NOTES

Applies to: user and admin workstations, servers, domain controllers.

At risk: A map of all users, groups, computers, trusts and paths to administrator access.

Likely objective: Find the shortest path to domain administrator, and learn which accounts log on where.

Likely next move: Movement to the admin hosts the map reveals (section 8), and Kerberoasting (event 6.2).

Possible indicators

- Directory queries many times above a normal workstation.
- Access to samr, lsarpc and srvsvc pipes from a workstation.
- 4798 and 4799 events across many hosts from one source.
- A burst of queries soon after first logon.
- Queries at unusual hours.

7. DISCOVERY · TA0007

7.3 Network Share and File Discovery

PRIORITY **MEDIUM** ATT&CK T1135 Network Share Discovery | T1083 File and Directory Discovery HOST PLAYBOOK 7.4

High if the source is not a normal user of the shares or the shares hold sensitive data.

TRIGGER

One host opening SMB connections to many servers and workstations in a short period, share enumeration calls, or recursive listing of a share.

RESPONSE STEPS

1. **Find hosts connecting to many SMB destinations.**
   - Splunk: `index=net dest_port=445 | bin _time span=10m | stats dc(dest_ip) as targets by _time src_ip | where targets>10`
   - Arkime: `ip.src==<host_ip> && port.dst==445` then SPI View on `ip.dst`.

2 **Find the shares and files browsed.**

Arkime `ip.src==<host_ip> && protocols==smb` then SPI View on `smb.share` and `smb.fn`.

Splunk `index=wineventlog EventCode=5140 Source_Address=<host_ip> | stats count by host Share_Name`

3 **Count the files touched on the file server.**

Logs File share auditing (event 5145) must be on.

Splunk `index=wineventlog host=<file_server_name> EventCode=5145 Source_Address=<host_ip> | stats dc(Relative_Target_Name) as files by Share_Name | sort -files`

4 **Check for access to restricted shares.**

Splunk `index=wineventlog EventCode=5140 Source_Address=<host_ip> Share_Name IN (<restricted_shares>) | stats count by host Share_Name Account_Name`

5 **Ask the host team to review the source host.**

Host Run Host playbook event 7.4 on the source host.

CONTAINMENT

- Allow file sharing (port 445) to the file server only from the networks that use each share.
- Block the source host from file sharing to servers it does not normally use.
- Ask the directory administrators to disable the account if it is not the host's normal user.

ESCALATE IF

restricted shares were accessed, the account is privileged, or the listing is followed by large reads (event 9.1).

EVIDENCE TO RECORD

source host and account, servers and shares touched, file counts, times (UTC), search strings.

NOTES

Applies to: file servers, user and admin workstations in any segment.

At risk: The names and locations of documents, and which shares the account can read.

Likely objective: Locate data to steal, and find scripts and configuration files that hold credentials.

Likely next move: Bulk reads (event 9.1), staging and archiving (event 9.2).

Possible indicators

- One host connecting to many servers on port 445.
- Access to shares in another segment.
- Recursive listing of many folders.
- Access to administrative shares (C$, ADMIN$) from a workstation.
- Access to shares the account has never used.

8 TA0008 Lateral Movement

The adversary moves from one host to another. Every event here has a source (where the adversary already is) and a destination. Investigate both, and run the Host playbook on each. Remote execution through WMI and service creation is covered in events 2.1 and 2.2. Movement between segments is covered in event 8.6.

8. LATERAL MOVEMENT · TA0008

8.1 Remote Services: Remote Desktop Protocol

PRIORITY **HIGH** ATT&CK T1021.001 Remote Desktop Protocol HOST PLAYBOOK 8.1

Critical for privileged accounts, servers, or a connection between segments.

TRIGGER

A remote desktop session (port 3389) from one workstation to another, from a host outside the IT admin range, at unusual hours, or from one host to many.

RESPONSE STEPS

1. **Find remote desktop sessions to the destination.**
   - Arkime: `ip.dst==<dst_ip> && port.dst==3389` then SPI View on `ip.src` and `rdp.cookie`.
   - Splunk: `index=net dest_ip=<dst_ip> dest_port=3389 | stats count min(_time) as first max(_time) as last by src_ip | convert ctime(first) ctime(last)`
2. **Confirm the logon and the account.**
   - Logs: Windows Security 4624 (type 10) and 4778 and 4779 (reconnect and disconnect) on the destination.
   - Splunk: `index=wineventlog EventCode=4624 Logon_Type=10 host=<dst_host> | stats count by Account_Name Source_Network_Address`
3. **Check whether the source connected to many hosts.**
   - Splunk: `index=net src_ip=<src_ip> dest_port=3389 | bin _time span=1h | stats dc(dest_ip) as targets by _time | where targets>3`
4. **Check session length and data volume.**
   - Arkime: `ip.dst==<dst_ip> && port.dst==3389` then sort by session length and bytes. Large transfers from the destination can be file copies through drive redirection.
5. **Check how the adversary reached the source.**
   - Arkime: `ip.dst==<src_ip> && port.dst==[3389,445,22,5985]` then SPI View on `ip.src`.
6. **Ask the host team to review both hosts.**
   - Host: Run Host playbook event 8.1 on the destination and the source.

CONTAINMENT

- Block remote desktop (port 3389) from the source to the destination.
- Allow remote desktop to servers only from the trusted management workstation. Block it from all other hosts.
- Ask the host team to log off the session and isolate both hosts if anything ran. Disable the account.

ESCALATE IF

a privileged account was used, the connection was workstation to workstation or between segments, or actions were taken in the session.

EVIDENCE TO RECORD

source and destination, account, session times (UTC), bytes transferred, search strings, Arkime session tags.

NOTES

Applies to: servers, jump hosts, admin and user workstations with remote desktop enabled.

At risk: Interactive control of the destination as the account used, and everything that account can reach.

Likely objective: Move through the network with a method that looks like normal administration.

Likely next move: Credential theft on the destination, then further hosts or the domain controller.

Possible indicators

- Remote desktop between user workstations.
- Remote desktop from outside the IT admin range.
- A service account using remote desktop.
- One host opening remote desktop to many others.
- 4778 and 4779 events at odd hours.

8. LATERAL MOVEMENT · TA0008

8.2 Remote Services: SMB and Windows Admin Shares

PRIORITY **HIGH** ATT&CK T1021.002 SMB/Windows Admin Shares | T1570 Lateral Tool Transfer HOST PLAYBOOK 8.2

Critical if executables were transferred, a privileged account was used, or several destinations were hit.

TRIGGER

A network logon (4624 type 3, often with 4672) followed by admin share access (ADMIN$, C$ or IPC$) from a non-admin host, executables or scripts written over SMB, or one source writing the same file to many hosts.

RESPONSE STEPS

1. **Confirm the share access.**
   - Arkime: `ip.dst==<dst_ip> && smb.share==[*ADMIN$,*C$,*IPC$]` then SPI View on `ip.src`, `smb.share` and `smb.fn`.
   - Splunk: `index=wineventlog EventCode=5140 host=<dst_host> | stats count by Share_Name Source_Address Account_Name`
2. **Find files written over SMB.**
   - Arkime: `ip.dst==<dst_ip> && smb.fn==[*.exe,*.dll,*.ps1,*.bat,*.vbs,*.lnk]` then SPI View on `smb.fn`.
   - Logs: Arkime does not see file names on encrypted SMB sessions. Use Splunk share auditing (5145) instead.
3. **Check whether the same file went to other hosts.**
   - Arkime: `ip.src==<src_ip> && protocols==smb && smb.fn==<file_name>` then SPI View on `ip.dst`.
4. **Check whether the files ran.**
   - Splunk: `index=wineventlog EventCode IN (7045,4698) host=<dst_host> | table _time EventCode Service_Name Task_Name`
5. **Ask the host team to review both hosts.**
   - Host: Run Host playbook event 8.2 on the source and the destination.

CONTAINMENT

- Block file sharing (port 445) from the source to the destination.
- Block file sharing between workstations as a standing rule.
- Disable the account and ask the host team to isolate both hosts. Remove the transferred files once evidence is collected.

ESCALATE IF

executables were transferred, a privileged account was used, or several destinations were hit.

EVIDENCE TO RECORD

source and destination, account, shares and files, hashes, execution method, times (UTC), search strings.

NOTES

Applies to: servers, domain controllers, file servers, admin and user workstations.

At risk: Files placed on the destination and, if they ran, code execution there.

Likely objective: Deliver tools and run them on the next host.

Likely next move: Execution of the files (event 2.2), credential theft on the destination, and the same step to more hosts.

Possible indicators

- Access to ADMIN$ or C$ from non-admin hosts.
- Randomly named executables written to C:\Windows or Temp.
- The same file hash on several hosts.
- 4648 explicit credential use on the source.
- Writes to many hosts from one source.

8. LATERAL MOVEMENT · TA0008

8.3 Remote Services: WinRM and PowerShell Remoting

PRIORITY **HIGH** ATT&CK T1021.006 Windows Remote Management HOST PLAYBOOK 8.3

Critical for privileged accounts or servers.

TRIGGER

Sessions to ports 5985 or 5986 from a host outside the IT admin range, WinRM events on the destination, or one source connecting to many hosts.

RESPONSE STEPS

1. **Find sessions to the destination.**
   - Arkime: `ip.dst==<dst_ip> && port.dst==[5985,5986]` then SPI View on `ip.src` and `http.user-agent`.
   - Splunk: `index=net dest_ip=<dst_ip> dest_port IN (5985,5986) | stats count min(_time) as first by src_ip | convert ctime(first)`

2 **Confirm the logon and the account.**

Logs Microsoft-Windows-WinRM/Operational 91 (session created) and Windows Security 4624 (type 3) on the destination.

Splunk `index=wineventlog EventCode=4624 Logon_Type=3 host=<dst_host> Source_Network_Address=<src_ip> | stats count by Account_Name`

3 **Check how many hosts the source connected to.**

Splunk `index=net src_ip=<src_ip> dest_port IN (5985,5986) | bin _time span=1h | stats dc(dest_ip) as targets by _time | where targets>3`

4 **Check what the destination did after the session.**

Splunk `index=net src_ip=<dst_ip> NOT dest_ip=<local_range> | stats count min(_time) as first by dest_ip dest_port | convert ctime(first) | sort first`

5 **Ask the host team to review both hosts.**

Host Run Host playbook event 8.3 on the destination and the source.

CONTAINMENT

- Block ports 5985 and 5986 from the source to the destination.
- Allow remote management to servers only from the trusted management workstation. Block it from all other hosts.
- Disable the account and ask the host team to isolate both hosts if commands ran.

ESCALATE IF

a privileged account was used, the destination is a server or domain controller, or several destinations were hit.

EVIDENCE TO RECORD

source and destination, account, session times (UTC), user agent, search strings, Arkime session tags.

NOTES

Applies to: servers, domain controllers, admin and user workstations with remote management enabled.

At risk: Command execution on the destination as the account used.

Likely objective: Run commands on many hosts using a built-in management feature.

Likely next move: Credential theft, further hosts, and deployment at scale (event 12.2).

Possible indicators

- Ports 5985 or 5986 from a non-admin host.
- The WinRM client user agent from a workstation.
- One source connecting to many hosts.
- New WinRM sessions outside change windows.
- Outbound connections from the destination soon after.

8. LATERAL MOVEMENT · TA0008

8.4 Remote Services: SSH

PRIORITY HIGH ATT&CK T1021.004 SSH HOST PLAYBOOK 8.4

Critical for privileged accounts, servers, network devices, or a connection between segments.

TRIGGER

SSH sessions between workstations, from user hosts to servers or routers, from outside the IT admin range, or SSH sessions with long duration and large volume.

RESPONSE STEPS

1 **Find SSH sessions to the destination.**

Arkime `ip.dst==<dst_ip> && protocols==ssh` then SPI View on `ip.src` and `port.dst`.

Splunk `index=net dest_ip=<dst_ip> dest_port=22 | stats count min(_time) as first max(_time) as last by src_ip | convert ctime(first) ctime(last)`

2 **Confirm the logon and the account.**

Logs `/var/log/auth.log` (Debian and Ubuntu) or `/var/log/secure` (RHEL) on the destination.

Splunk `index=network_devices sshd "Accepted" | rex "Accepted \S+ for (?<user>\S+) from (?<src>\S+)" | stats count by host user src`

3 **Look for tunnelling.**

Arkime `ip.dst==<dst_ip> && protocols==ssh && databytes>10000000` then sort by session length.

4 **Check how many hosts the source connected to.**

Splunk `index=net src_ip=<src_ip> dest_port=22 | bin _time span=1h | stats dc(dest_ip) as targets by _time | where targets>3`

5 **Ask the host team to review both hosts.**

Host Run Host playbook event 8.4 on the destination and the source.

CONTAINMENT

- Block SSH (port 22) from the source to the destination.
- Allow SSH to servers and core routers only from the trusted management workstation. Block it from all other hosts.
- Disable the account, remove unknown keys through the host team, and ask the host team to isolate both hosts if commands ran.

ESCALATE IF

a privileged account was used, the destination is a server or network device, or the session carried large volumes.

EVIDENCE TO RECORD

source and destination, account, session times (UTC), bytes transferred, search strings, Arkime session tags.

NOTES

Applies to: Linux servers, core routers, jump hosts, any host with SSH enabled.

At risk: Shell access on the destination as the account used.

Likely objective: Move to Linux hosts and network devices, and tunnel other traffic through SSH.

Likely next move: Credential theft, persistence (SSH keys), and tunnelling (event 10.4).

Possible indicators

- SSH between user workstations.
- SSH to a core router from outside the IT admin range.
- A long SSH session with large two-way volume.
- One host connecting by SSH to many others.
- A first-time SSH user for the host.

8. LATERAL MOVEMENT · TA0008

8.5 Pass-the-Hash, Pass-the-Ticket and NTLM Relay

PRIORITY HIGH ATT&CK T1550.002 Pass the Hash | T1550.003 Pass the Ticket | T1557.001 NTLM Relay HOST PLAYBOOK 8.5 | 6.5

Critical for privileged accounts.

TRIGGER

NTLM network logons (4624 type 3) for accounts that normally use Kerberos, a ticket used from two different addresses, a logon source that does not match the account's earlier activity, or one account logging on to many hosts in a short period.

RESPONSE STEPS

1. **Find NTLM network logons by privileged accounts.**
   Splunk `index=wineventlog EventCode=4624 Logon_Type=3 Authentication_Package=NTLM Account_Name IN (<admin_accounts>) | stats count by Account_Name Source_Network_Address host`
2. **Check for a ticket used from more than one address.**
   Splunk `index=wineventlog EventCode=4769 | stats dc(Client_Address) as sources by Account_Name | where sources>1`
3. **Count hosts logged on to by the account.**
   Splunk `index=wineventlog EventCode=4624 Account_Name=<user> | bin _time span=10m | stats dc(host) as hosts by _time | where hosts>3`
4. **Check SMB authentications on the network.**
   Arkime `ip.src==<src_ip> && protocols==smb` then SPI View on `smb.user` and `ip.dst`.
5. **Check for explicit credential use on the source.**
   Splunk `index=wineventlog EventCode=4648 host=<src_host> | stats count by Account_Name Target_Server_Name`
6. **Ask the host team to review the source and destination hosts.**
   Host Run Host playbook events 8.5 and 6.5 on the source and the destination.

CONTAINMENT

- Block file sharing and remote login ports from the source host to all other hosts.
- Disable the account. Ask the directory administrators to reset it after the source is contained.
- Recommend restricting NTLM authentication where the environment allows it.

ESCALATE IF

a privileged account was used, the source is not the account's normal host, or several hosts were logged on to.

EVIDENCE TO RECORD

account, source and destination hosts, authentication type, times (UTC), search strings, Arkime session tags.

NOTES

Applies to: servers, domain controllers, admin and user workstations.

At risk: Access as the account with no password. The adversary does not need to crack the hash.

Likely objective: Reuse stolen hashes or tickets to reach hosts quietly.

Likely next move: More hosts, then the domain controller (events 6.3 and 12.2).

Possible indicators

- NTLM logons by accounts that normally use Kerberos.
- One account logging on to many hosts within minutes.
- The same ticket used from two addresses.
- Logons from an address that does not match the account's earlier activity.
- 4648 events from workstations.

8.6 Movement Between Segments Outside Agreed Flows

PRIORITY **HIGH** ATT&CK T1021 Remote Services | T1570 Lateral Tool Transfer HOST PLAYBOOK 8.1 | 8.2 | 8.3 | 8.4

Critical if the destination is a sensitive segment or a network device.

TRIGGER

A connection from one segment to another that is not in the normal traffic table, for example a user segment connecting to a segment that holds sensitive records, or one user segment connecting to another.

RESPONSE STEPS

1. **Find the connections between the two segments.**
   - Arkime: `ip.src==<segment_range> && ip.dst==<other_segment_range>` then SPI View on `ip.src`, `ip.dst` and `port.dst`.
   - Splunk:
     ```
     index=net src_ip=<segment_range> dest_ip=<other_segment_range> | stats count values(dest_port) as ports min(_time) as first by src_ip dest_ip | convert ctime(first)
     ```
2. **Compare the flow with the normal traffic table.**
   - Logs: Normal traffic between segments table in this playbook.
3. **Identify the account used.**
   - Splunk:
     ```
     index=wineventlog EventCode=4624 Source_Network_Address=<src_ip> host=<dst_host> | stats count by Account_Name Logon_Type
     ```
4. **Find out why the core router allowed the flow.**
   - Router: `show configuration commands | match "firewall name"` · `show system commit`
5. **Check what else the source host connected to.**
   - Splunk:
     ```
     index=net src_ip=<src_ip> | stats count min(_time) as first by dest_ip dest_port | convert ctime(first) | sort first
     ```
6. **Ask the host team to review both hosts.**
   - Host: Run the Host playbook event that matches the port: 8.1 (3389), 8.2 (445), 8.3 (5985 or 5986) or 8.4 (22).

CONTAINMENT

- Block all traffic between the two segments on the core routers, except the agreed flows.
- Block the source host from connecting to any other segment.
- Ask the host team to isolate the source and, if anything ran, the destination.

ESCALATE IF

the destination is a sensitive segment or a network device, or a privileged account was used.

EVIDENCE TO RECORD

source and destination segments and hosts, ports, account, times (UTC), rule that allowed the flow, search strings.

NOTES

Applies to: all segments.

At risk: Data and systems in the destination segment, and the separation between segments.

Likely objective: Reach the data or systems in the destination segment.

Likely next move: Collection of that segment's data (event 9.1) and exfiltration (section 11), or further spread.

Possible indicators

- A user segment connecting to a sensitive segment outside agreed lookups.
- Workstations connecting to workstations in another segment.
- A flow that is not in the normal traffic table.
- Management ports used across segments from non-admin hosts.
- A flow that appears just after a router configuration change.

9 TA0009 Collection

The adversary gathers the data they came for. Network analysts see unusual reads from shares and databases, files collected in one place and copied out, and mailbox access. Volume matters. Compare it with the baseline for that segment.

9. COLLECTION · TA0009

9.1 Bulk Reads from Shares or Databases

PRIORITY **HIGH** ATT&CK T1039 Data from Network Shared Drive | T1213 Data from Information Repositories HOST PLAYBOOK 9.3

Critical if the data is sensitive, or a privileged account was used.

TRIGGER

One client reading far more data than baseline from a file server or database, a client touching shares it has not used before, or a spike in file opens (5145) from one source.

RESPONSE STEPS

1. **Find the top readers.**
   - Splunk: `index=net dest_ip=<file_server_ip> dest_port=445 | stats sum(bytes) as bytes by src_ip | eval MB=round(bytes/1048576,1) | sort -MB`
   - Arkime: `ip.src==<file_server_ip> && protocols==smb && databytes.src>100000000` then SPI View on `ip.dst`.
2. **Count the files and shares accessed.**
   - Logs: File share auditing (event 5145) must be on.
   - Splunk: `index=wineventlog host=<file_server_name> EventCode=5145 | stats dc(Relative_Target_Name) as files dc(Share_Name) as shares by Source_Address Account_Name | sort -files`
3. **Check database reads.**
   - Splunk: `index=net dest_ip=<db_server_ip> | stats sum(bytes) as bytes by src_ip | eval MB=round(bytes/1048576,1) | sort -MB`
   - Arkime: `ip.dst==<db_server_ip>` then SPI View on `ip.src` and `port.dst`. Compare byte counts across clients.
4. **Compare against the last 30 days.**
   - Splunk: `index=net dest_ip=<file_server_ip> dest_port=445 src_ip=<client_ip> earliest=-30d | timechart span=1d sum(bytes) as bytes`
5. **Ask the host team to review the client host.**
   - Host: Run Host playbook event 9.3 on the client host.

CONTAINMENT

- Block the client from file sharing to the file server.
- Allow file sharing (port 445) to the file server only from the networks that use each share.
- Ask the directory administrators to disable the account if it is not the client's normal user.

ESCALATE IF

the data is from a sensitive segment, the account is privileged, or a transfer off the network follows (section 11).

EVIDENCE TO RECORD

client and server, account, shares or databases, volumes and file counts, baseline comparison, times (UTC), search strings.

NOTES

Applies to: file servers, database servers, and any host holding shared data.

At risk: The contents of the shares and databases the client can read.

Likely objective: Collect data for theft, and find credentials in scripts and configuration files.

Likely next move: Staging and archiving (event 9.2), then exfiltration (section 11).

Possible indicators

- One client reading many times its normal volume.
- A client reading shares from another segment.
- A spike in 5145 events from one source.
- Reads at unusual hours.
- A database client that has not connected before.

9. COLLECTION · TA0009

9.2 Data Staged and Archived

PRIORITY **HIGH** ATT&CK T1074.002 Remote Data Staging | T1560 Archive Collected Data HOST PLAYBOOK 9.1 9.2

Critical if a transfer off the network follows.

TRIGGER

Archives (.zip, .7z, .rar) or large files created on a share and then copied by a single host, or one host receiving large volumes from many hosts.

RESPONSE STEPS

1. **Find archives written or read over SMB.**
   Arkime `protocols==smb && smb.fn==[*.zip,*.7z,*.rar,*.tar,*.gz]` then SPI View on `ip.src`, `ip.dst` and `smb.fn`.

2. **Find hosts receiving data from many sources.**
   Splunk
   ```
   index=net dest_ip=<local_range> | stats dc(src_ip) as sources sum(bytes) as bytes by dest_ip | where sources>5 | sort -bytes
   ```

3. **Check the staging host's outbound traffic.**
   Splunk
   ```
   index=net src_ip=<host_ip> NOT dest_ip=<local_range> | stats sum(bytes_out) as bytes by dest_ip dest_port | sort -bytes
   ```

4. **Check what the staging host received.**
   Arkime `ip.dst==<host_ip> && protocols==smb` then sort by bytes and SPI View on `ip.src` and `smb.fn`.

5. **Ask the host team to review the staging host.**
   Host Run Host playbook events 9.1 and 9.2 on the staging host.

CONTAINMENT

- Block the staging host from sending any traffic off the network.
- Block the sources that wrote to the staging host from connecting to it.
- Do not delete the archives. Record their names, paths and hashes first, then ask the host team to preserve them.

ESCALATE IF

the staged data is from a sensitive segment or a transfer off the network has started.

EVIDENCE TO RECORD

staging host, archive names, sizes and hashes, sources, times (UTC), search strings.

NOTES

Applies to: file servers, workstations, and any host with large free storage.

At risk: A single collection of data from many places, ready to leave the network.

Likely objective: Gather data in one place and prepare it for exfiltration.

Likely next move: Exfiltration (section 11).

Possible indicators

- Archives created on a share by an account that does not create them.
- One host receiving data from many hosts.
- A rise in outbound volume from the staging host.
- Archive types on servers that do not normally hold them.
- Staging outside working hours.

9. COLLECTION · TA0009

9.3 Email Collection

PRIORITY **HIGH** ATT&CK T1114.002 Remote Email Collection | T1114.003 Email Forwarding Rule HOST PLAYBOOK 9.4

Critical if executive or senior staff mailboxes are involved, or mail is forwarded to external addresses.

TRIGGER

A new forwarding or redirect rule, mailbox access from a host or account that does not normally use it, large mail downloads over IMAP or MAPI, or mail forwarded to an external address.

RESPONSE STEPS

1. **Find large mail client sessions.**
   Splunk
   ```
   index=net dest_ip=<mail_server_ip> dest_port IN (110,143,443,993,995) | stats sum(bytes) as bytes by src_ip | eval MB=round(bytes/1048576,1) | sort -MB
   ```
   Arkime `ip.dst==<mail_server_ip> && protocols==[imap,pop3]` then sort by bytes and SPI View on `ip.src`.

2. **Check for forwarding rules.**
   Logs Mail server administration and audit logs for rule creation.
   Splunk `index=mail (forward OR redirect OR "inbox rule") | table _time host _raw`

3. **Check outbound mail from the mailbox.**

   Splunk `index=mail sender=<mailbox> direction=outbound | stats count sum(size) as bytes by recipient_domain | sort -bytes`

4. **Check where the mailbox was accessed from.**

   Splunk `index=mail user=<mailbox> | stats count min(_time) as first by src_ip | convert ctime(first)`

5. **Ask the host team to review the hosts that accessed the mailbox.**

   Host Run Host playbook event 9.4 on the hosts that accessed the mailbox.

CONTAINMENT

- Ask the mail administrators to remove the forwarding rule and reset the mailbox credentials.
- Block the external domains that receive forwarded mail.
- Block the hosts that accessed the mailbox from the mail server, except through the approved client path.

ESCALATE IF

executive or senior staff mailboxes are involved, or forwarding to an external address was found.

EVIDENCE TO RECORD

mailbox, rule details, forwarding destination, access sources, volume, times (UTC), search strings.

NOTES

Applies to: the mail server and any mail client.

At risk: Orders, plans and staff correspondence in the mailbox, and the ability to read future mail.

Likely objective: Read executive and operational mail, and keep a copy leaving the network.

Likely next move: Phishing from the mailbox (event 1.2), and exfiltration of mail (event 11.3).

Possible indicators

- A new forwarding rule to an external address.
- Mailbox access from a host the user does not use.
- Large IMAP or MAPI sessions.
- Mail accessed outside working hours.
- Several mailboxes accessed from one host.

10 TA0011 Command and Control

The adversary keeps remote control of hosts inside the network. Analyse traffic where it leaves the network. Beacons repeat at regular intervals and are small. Use destination, timing and size to find them.

10. COMMAND AND CONTROL · TA0011

10.1 Application Layer Protocol: Web Beaconing

PRIORITY **HIGH** ATT&CK T1071.001 Web Protocols | T1573 Encrypted Channel HOST PLAYBOOK 10.1

Critical if the source is a server, domain controller or a host in a sensitive segment.

TRIGGER

Outbound web connections from one host to one destination at regular intervals, small requests with uniform responses, a rare destination, a self-signed or recently issued certificate, or an uncommon JA3 hash.

RESPONSE STEPS

1. **Find connections at regular intervals.**
   - Splunk: `index=net src_ip=<host_ip> NOT dest_ip=<local_range> | sort 0 _time | streamstats current=f last(_time) as prev by dest_ip | eval gap=_time-prev | stats count avg(gap) as avg stdev(gap) as sd by dest_ip | where count>20 AND sd<avg*0.2`
   - Arkime: `ip.src==<host_ip> && ip.dst!=<local_range> && protocols==tls` then SPI View on `ip.dst` and sort by Start Time.
2. **Inspect the certificate and TLS fingerprint.**
   - Arkime: `ip.src==<host_ip> && ip.dst==<dst_ip>` then SPI View on `cert.issuer.cn`, `cert.subject.cn` and `tls.ja3`.
3. **Inspect any unencrypted web traffic.**
   - Arkime: `ip.src==<host_ip> && protocols==http && ip.dst!=<local_range>` then SPI View on `host.http`, `http.uri` and `http.user-agent`.
4. **Check the name lookups for the destination.**
   - Splunk: `index=dns src_ip=<host_ip> | stats count min(_time) as first by query | convert ctime(first) | sort first`
5. **Check which other hosts contact the same destination.**
   - Splunk: `index=net dest_ip=<dst_ip> | stats dc(src_ip) as sources values(src_ip) as hosts by dest_ip`
6. **Ask the host team to review the source host.**
   - Host: Run Host playbook event 10.1 on the source host.

CONTAINMENT

- Block the destination addresses on the core routers and sinkhole the domains in name resolution.
- Block all traffic from the host off the network, then ask the host team to isolate it.
- Watch for the implant switching to a new destination.

ESCALATE IF

the host is a server or in a sensitive segment, several hosts contact the same destination, or data volumes are large.

EVIDENCE TO RECORD

source host, destination addresses and domains, interval and sizes, certificate and fingerprint details, first and last times (UTC), search strings, Arkime session tags.

NOTES

Applies to: any host with off-network access.

At risk: Remote control of the host, and everything the host and its users can reach.

Likely objective: Keep long-term remote access, receive commands and run tools.

Likely next move: Discovery and movement to other hosts (sections 7 and 8), and exfiltration over the same channel (event 11.2).

Possible indicators

- Connections to one destination at near-equal intervals.
- Small requests with uniform response sizes.
- A self-signed or recent certificate.
- A TLS fingerprint seen on few other hosts.
- A destination with no history in name resolution logs.

10. COMMAND AND CONTROL · TA0011

10.2 Application Layer Protocol: DNS Command and Control and Tunnelling

PRIORITY **HIGH** ATT&CK T1071.004 DNS | T1572 Protocol Tunneling HOST PLAYBOOK 10.2

Critical if the volume is high or the source is a server.

TRIGGER

A host sending many DNS queries with long or random subdomains to one domain, many TXT or NULL record queries, large DNS responses, or DNS queries sent straight to an external server instead of the internal resolver.

RESPONSE STEPS

1. **Find the query volume per domain.**
   - Splunk: `index=dns src_ip=<host_ip> | rex field=query "(?<domain>[^.]+\.[^.]+)$" | stats count dc(query) as unique by domain | sort -unique`
2. **Find long query names.**
   - Splunk: `index=dns src_ip=<host_ip> | eval len=len(query) | where len>50 | stats count by query`
   - Arkime: `ip.src==<host_ip> && protocols==dns` then SPI View on `host.dns`.
3. **Find unusual record types.**
   - Arkime: `ip.src==<host_ip> && protocols==dns && dns.query.type==TXT`
4. **Find DNS sent straight to an external server.**
   - Arkime: `port.dst==53 && ip.src==<local_range> && ip.dst!=<dns_server_ip>`
   - Splunk: `index=net dest_port=53 NOT dest_ip=<dns_server_ip> NOT src_ip=<dns_server_ip> | stats count by src_ip dest_ip`
5. **Ask the host team to review the source host.**
   - Host: Run Host playbook event 10.2 on the source host.

CONTAINMENT

- Block DNS (port 53) from every host to anywhere off the network, except the internal resolver. Make this a standing rule.
- Sinkhole the domain in name resolution.
- Ask the host team to isolate the source host.

ESCALATE IF

the source is a server or domain controller, the volume is high, or several hosts query the same domain.

EVIDENCE TO RECORD

source host, domain, query counts and examples, record types, times (UTC), search strings, Arkime session tags.

NOTES

Applies to: any host. Domain controllers and DNS servers can also act as relays.

At risk: A channel that passes through most filtering, used for control or for sending data out.

Likely objective: Command and control or exfiltration that avoids web filtering.

Likely next move: Data theft over DNS (event 11.3), and further control of the host.

Possible indicators

- Many unique subdomains under one domain.
- Query names longer than 50 characters.
- High volumes of TXT or NULL queries.
- A workstation sending DNS to an external server.
- Queries at regular intervals.

10. COMMAND AND CONTROL · TA0011

10.3 Remote Access Software

PRIORITY **MEDIUM** ATT&CK T1219 Remote Access Software HOST PLAYBOOK 10.3

High if installed without approval on servers or in sensitive segments.

TRIGGER

Connections to known remote support or tunnelling service domains, or a new long-lived outbound session from a host that has no approved remote support tool.

RESPONSE STEPS

1. **Find connections to remote access services.**
   - Splunk: `index=dns query IN ("*anydesk*","*teamviewer*","*screenconnect*","*ngrok*","*splashtop*","*rustdesk*") | stats count by src_ip query`
   - Arkime: `host.dns==[*anydesk*,*teamviewer*,*screenconnect*,*ngrok*,*rustdesk*]` then SPI View on `ip.src`.

2 **Check session length and volume.**

Arkime `ip.src==<host_ip> && host.dns==<service_domain>` then sort by session length and bytes.

3 **Compare with the approved tools list.**

Logs The approved remote support tools for each segment.

4 **Check which accounts and hosts are involved.**

Splunk `index=wineventlog EventCode=4624 host=<host_name> | stats count min(_time) as first by Account_Name Logon_Type | convert ctime(first)`

5 **Ask the host team to find the software.**

Host Run Host playbook event 10.3 on the host.

CONTAINMENT

- Block the service domains and addresses on the core routers and in name resolution.
- Ask the host team to remove the software and isolate the host if the tool is not approved.
- Allow approved remote support tools only from the hosts that need them.

ESCALATE IF

the tool is not approved, it is on a server or in a sensitive segment, or it was installed outside working hours.

EVIDENCE TO RECORD

host, service domain, first and last times (UTC), volume, account, approved tool comparison, search strings.

NOTES

Applies to: user and admin workstations, servers.

At risk: Interactive control of the host that bypasses the usual management path.

Likely objective: A reliable remote access method that looks like legitimate support.

Likely next move: Interactive movement to other hosts, and data collection.

Possible indicators

- Connections to remote support domains from a host with no approved tool.
- A new long-lived outbound session.
- Installation outside working hours.
- The tool on a server or in a sensitive segment.
- Several hosts using the same new service.

10. COMMAND AND CONTROL · TA0011

10.4 Protocol Tunnelling and Proxy

PRIORITY HIGH ATT&CK T1572 Protocol Tunneling | T1090 Proxy | T1090.001 Internal Proxy HOST PLAYBOOK 10.4

Critical if tunnels start on a core router or server.

TRIGGER

Long-lived SSH, HTTPS or other sessions with traffic in both directions and unusual volume, GRE, IPsec, OpenVPN or WireGuard traffic to an unknown address, an internal host relaying connections for other hosts, or ICMP with large payloads.

RESPONSE STEPS

1 **Find tunnel protocols leaving the network.**

Arkime `ip.src==<local_range> && ip.dst!=<local_range> && (ip.protocol==[47,50] || port.dst==[500,4500,1194,51820])` then SPI View on `ip.src` and `ip.dst`.

2 **Find long, high-volume sessions.**

Arkime `ip.src==<local_range> && ip.dst!=<local_range> && databytes>50000000` then sort by session length.

3 **Find internal relays.**

Arkime `ip.dst==<host_ip> && ip.src==<local_range> && port.dst>1024` then SPI View on `port.dst` and `ip.src`.

4 **Find ICMP with large payloads.**

Arkime `ip.protocol==1 && databytes>500` then SPI View on `ip.src` and `ip.dst`.

5 **Check for tunnels created on core routers.**

Router See event 13.2.

6 **Ask the host team to review the relay host.**

Host Run Host playbook event 10.4 on the relay host.

CONTAINMENT

- Block tunnel protocols (GRE, IPsec, OpenVPN, WireGuard) from the segments to anywhere off the network, except approved tunnels.
- Block the destination address on the core routers.
- Block the relay host from receiving connections from other internal hosts. Ask the host team to isolate it.

ESCALATE IF

the tunnel starts on a core router or server, the destination is unknown, or several hosts use it.

EVIDENCE TO RECORD

source, relay host, destination, protocol, session length and volume, times (UTC), search strings, Arkime session tags.

NOTES

Applies to: any host with off-network access, core routers.

At risk: A hidden path that carries other traffic past filtering and monitoring.

Likely objective: Pass command and control, tools or data through an allowed protocol, or use one host to reach others.

Likely next move: Exfiltration (section 11), and access to segments that have no direct path.

Possible indicators

- GRE, IPsec or WireGuard traffic from a host.
- A long session with large two-way volume.
- An internal host that accepts connections on a high port from many hosts.
- ICMP with large payloads.
- A new tunnel at the same time as a configuration commit.

11 TA0010 Exfiltration

The adversary moves data out of the network. Use the network egress point to see destinations and volume. Judge volume against what the source normally sends. Hosts that hold sensitive records should send very little off the network.

11. EXFILTRATION · TA0010

11.1 Exfiltration Over Web Service: Cloud Storage

PRIORITY **CRITICAL** ATT&CK T1567.002 Exfiltration to Cloud Storage | T1567 Exfiltration Over Web Service HOST PLAYBOOK 11.1

Critical if data from a sensitive segment is involved; High otherwise.

TRIGGER

Large uploads to a cloud storage or file sharing site, a large amount of outbound data from a host that normally sends little, or a transfer outside working hours.

RESPONSE STEPS

1. **Find the largest outbound senders.**
   - Splunk: `index=net NOT dest_ip=<local_range> | stats sum(bytes_out) as bytes by src_ip | eval MB=round(bytes/1048576,1) | sort -MB | head 20`
   - Arkime: `ip.src==<local_range> && ip.dst!=<local_range>` then sort by `databytes.src`.
2. **Identify the destinations.**
   - Splunk: `index=net src_ip=<host_ip> NOT dest_ip=<local_range> | stats sum(bytes_out) as bytes by dest_ip dest_port | sort -bytes`
   - Arkime: `ip.src==<host_ip> && ip.dst!=<local_range>` then SPI View on `host.http`, `host.dns`, `tls.ja3` and `cert.subject.cn`.
3. **Compare against the host's normal volume.**
   - Splunk: `index=net src_ip=<host_ip> NOT dest_ip=<local_range> earliest=-30d | timechart span=1d sum(bytes_out) as bytes`
4. **Find what was collected before the transfer.**
   - Splunk: Use the searches in events 9.1 and 9.2 for the host.
5. **Ask the host team to review the source host.**
   - Host: Run Host playbook event 11.1 on the source host.

CONTAINMENT

- Block all traffic from the host off the network, then ask the host team to isolate it.
- Block the destination addresses and domains on the core routers and in name resolution.
- Block all traffic from segments that hold sensitive records off the network as a standing rule.

ESCALATE IF

the data is from a sensitive segment, the volume is large, or the transfer is still running.

EVIDENCE TO RECORD

source host, destination, volume and times (UTC), files collected beforehand, baseline comparison, search strings, exported packet capture.

NOTES

Applies to: any host with off-network access, in particular file servers, database servers and staging hosts.

At risk: The data transferred. Once it leaves, the loss cannot be undone.

Likely objective: Take the collected data out of the network.

Likely next move: More transfers over other channels, extortion, and deletion of the original data.

Possible indicators

- A large upload to a file sharing or storage domain.
- A host sending far above its normal volume.
- A transfer outside working hours.
- A host that holds sensitive records sending off the network.
- A transfer that follows archive creation.

11. EXFILTRATION · TA0010

11.2 Exfiltration Over C2 Channel

PRIORITY **HIGH** ATT&CK T1041 Exfiltration Over C2 Channel HOST PLAYBOOK 11.2

Critical if uploads far exceed downloads on the channel.

TRIGGER

A beaconing destination (event 10.1) where the host sends far more than it receives, or the beacon size and frequency increase.

RESPONSE STEPS

1. **Identify the beaconing destination.**
   - Splunk: Use the beaconing search in event 10.1.
2. **Compare bytes sent and received.**
   - Splunk: `index=net src_ip=<host_ip> dest_ip=<dst_ip> | stats sum(bytes_out) as sent sum(bytes_in) as received count by dest_ip`
   - Arkime: `ip.src==<host_ip> && ip.dst==<dst_ip>` then compare `databytes.src` with `databytes.dst`.
3. **Find when the volume changed.**
   - Splunk: `index=net src_ip=<host_ip> dest_ip=<dst_ip> | timechart span=1h sum(bytes_out) as sent`
4. **Find what the host accessed before the increase.**
   - Splunk: Use the searches in events 9.1 and 9.2 for the host.
5. **Ask the host team to review the source host.**
   - Host: Run Host playbook event 11.2 on the source host.

CONTAINMENT

- Block the destination addresses on the core routers and sinkhole its domains in name resolution.
- Block all traffic from the host off the network, then ask the host team to isolate it.
- Keep a packet capture of the channel before blocking it, if the incident lead agrees.

ESCALATE IF

the volume is large, the host holds sensitive data, or several hosts use the same channel.

EVIDENCE TO RECORD

source host, destination, bytes sent and received, time the volume changed (UTC), search strings, exported packet capture.

NOTES

Applies to: any host with an established command and control channel.

At risk: The data sent over the channel.

Likely objective: Send stolen data out over a channel that is already open and trusted.

Likely next move: Further transfers, and use of the channel to receive new tools.

Possible indicators

- Bytes sent far above bytes received.
- Beacon size or frequency increasing.
- A sudden rise in volume to the beacon destination.
- Uploads that follow collection activity.
- Long sessions to a rare destination.

11. EXFILTRATION · TA0010

11.3 Exfiltration Over Alternative Protocol

PRIORITY **HIGH** ATT&CK T1048 Exfiltration Over Alternative Protocol T1048.003 Exfiltration Over Unencrypted Non-C2 Protocol

HOST PLAYBOOK 11.3

Critical if the volume is large or the data comes from a sensitive segment.

TRIGGER

Outbound FTP, SFTP, SCP, SMTP, ICMP or DNS with unusual volume from a host that does not normally use them, mail with large attachments to new external domains, or outbound mail from a host other than the mail server.

RESPONSE STEPS

1. **Find outbound mail sent directly from hosts.**
   - Splunk: `index=net dest_port IN (25,465,587) NOT src_ip=<mail_server_ip> NOT dest_ip=<mail_server_ip> | stats count sum(bytes_out) as bytes by src_ip dest_ip`
   - Arkime: `port.dst==25 && ip.src!=<mail_server_ip> && ip.dst!=<local_range>`

2 **Find outbound mail volume by sender and domain.**

Splunk `index=mail direction=outbound | stats sum(size) as bytes count by sender recipient_domain | sort -bytes`

3 **Find file transfer protocols leaving the network.**

Arkime `ip.src==<local_range> && ip.dst!=<local_range> && port.dst==[21,22,69,990]` then sort by `databytes.src`.

4 **Check DNS and ICMP volume.**

Splunk `index=dns | stats count dc(query) as unique by src_ip | sort -count`

Arkime `ip.protocol==1 && ip.src==<local_range> && ip.dst!=<local_range>` then sort by `databytes.src`.

5 **Ask the host team to review the source host.**

Host Run Host playbook event 11.3 on the source host.

CONTAINMENT

- Block outbound mail (port 25) from every host except the mail server. Make this a standing rule.
- Block FTP, SSH file transfer and ICMP from the segments to anywhere off the network, except approved flows.
- Block the external domains and addresses that received the data. Ask the mail administrators to suspend the sending account.

ESCALATE IF

the volume is large, the data comes from a sensitive segment, or the transfer is still running.

EVIDENCE TO RECORD

source host, protocol, destination, volume and times (UTC), mail details, search strings, exported packet capture.

NOTES

Applies to: any host with off-network access, the mail server.

At risk: The data sent, by a route that web filtering does not cover.

Likely objective: Send data out by a route that is allowed or checked less closely.

Likely next move: More transfers over other protocols, and extortion.

Possible indicators

- Outbound SMTP from a host that is not the mail server.
- Large attachments to a new external domain.
- FTP or SCP from a host that does not use them.
- High DNS or ICMP volume to one destination.
- Transfers outside working hours.

12 TA0040 Impact

The adversary damages, locks or disrupts systems or data. Impact events need the fastest response, and containment comes before evidence. Ransomware can encrypt shares within minutes, and a lost network link affects operations.

12. IMPACT · TA0040

12.1 Data Encrypted for Impact: Mass File Changes Over SMB

PRIORITY **CRITICAL** ATT&CK T1486 Data Encrypted for Impact HOST PLAYBOOK 12.1

Always critical. Contain first.

TRIGGER

A high rate of SMB writes, renames or deletes from one host, new file extensions or ransom notes on shares, or users reporting that files cannot be opened.

RESPONSE STEPS

1. **Identify the source of the writes. Do this first.**
   - Splunk `index=net dest_ip=<file_server_ip> dest_port=445 | bin _time span=1m | stats sum(bytes) as bytes by _time src_ip | sort -bytes | head 10`
   - Arkime `ip.dst==<file_server_ip> && protocols==smb` then sort by bytes and SPI View on `ip.src`.
2. **Look for ransom notes and new extensions.**
   - Arkime `ip.dst==<file_server_ip> && smb.fn==[*readme*,*decrypt*,*recover*,*restore*]`
   - Splunk `index=wineventlog EventCode=5145 host=<file_server_name> Relative_Target_Name IN ("*readme*","*decrypt*","*restore*") | stats count by Source_Address Relative_Target_Name`
3. **Find all affected servers and sources.**
   - Splunk `index=net dest_port=445 | bin _time span=1m | stats sum(bytes) as bytes by _time src_ip dest_ip | where bytes>500000000`
4. **Find how it spread.**
   - Logs Use events 2.2 and 8.2 on the source, and event 12.2 if it came from a domain controller.
5. **Check backups and snapshots.**
   - Arkime `ip.dst==<backup_server_ip>` then SPI View on `ip.src` and check for access that is not from the backup service.
6. **Ask the host team to review the source hosts.**
   - Host Run Host playbook event 12.1 on each source host.

CONTAINMENT

- Block file sharing (port 445) from the source host to the file server immediately. If several sources are writing, disconnect the file server from the network. Speed matters more than evidence here.
- Block file sharing between workstations and from workstations to servers other than the file servers they use.
- Confirm that backups and snapshots are intact and cannot be reached from the compromised accounts. Ask the host team to isolate the source hosts.

ESCALATE IF

always. Activate the major incident process and tell the incident lead.

EVIDENCE TO RECORD

source hosts, affected servers and shares, ransom note name and text, first write time (UTC), volume, search strings, Arkime session tags.

NOTES

Applies to: file servers, database servers, any host with shared data.

At risk: All data on the shares and servers reached. Without good backups, the loss may be permanent.

Likely objective: Lock data and demand payment, or destroy it.

Likely next move: More servers and shares, backups, and the domain controller for a wider push (event 12.2).

Possible indicators

- A high rate of SMB writes or renames from one host.
- New file extensions or ransom note files across shares.
- Backup systems accessed by an unexpected host.
- Several hosts writing to the same server.
- User reports of unreadable files.

12. IMPACT · TA0040

12.2 Mass Deployment from the Domain Controller or an Admin Host

PRIORITY **CRITICAL** ATT&CK T1484.001 Group Policy Modification | T1072 Software Deployment Tools | T1486 Data Encrypted for Impact HOST PLAYBOOK 12.1 2.5

Always critical.

TRIGGER

A domain controller or admin host starting SMB, RPC, WinRM or remote desktop connections to many hosts at once, many hosts connecting to SYSVOL or one share, or the same new file or service appearing on many hosts.

RESPONSE STEPS

1. **Find connections from the domain controller to workstations.**

   Arkime
   ```
   ip.src==<dc_ip> && ip.dst==<local_range> && port.dst==[135,445,3389,5985]
   ```
   Splunk
   ```
   index=net src_ip=<dc_ip> dest_port IN (135,445,3389,5985) | stats dc(dest_ip) as targets by dest_port
   ```

2. **Find fan-out from admin hosts.**

   Splunk
   ```
   index=net src_ip=<mgmt_range> dest_port IN (22,445,3389,5985) | bin _time span=5m | stats dc(dest_ip) as targets by _time src_ip | where targets>20
   ```

3. **Find the same service on many hosts.**

   Splunk
   ```
   index=wineventlog EventCode=7045 | stats dc(host) as hosts values(Service_File_Name) as files by Service_Name | where hosts>10
   ```

4. **Check for Group Policy changes.**

   Logs See event 4.2.

5. **Ask the host team to check for the same file hash on many hosts.**

   Host Run Host playbook events 12.1 and 2.5 on a sample of affected hosts.

CONTAINMENT

- Block the domain controller from starting connections to workstations on remote login and file sharing ports.
- Block the admin host that is pushing from connecting to any other machine. Disable the account used.
- If the push is still running, block all traffic between segments on the core routers until the source is found, with the incident lead's approval. Do not take the domain controller offline.

ESCALATE IF

always. Activate the major incident process and tell the incident lead.

EVIDENCE TO RECORD

source host and account, targets and count, ports, policy or service names, first connection time (UTC), search strings.

NOTES

Applies to: domain controllers, admin workstations, any host with deployment rights.

At risk: Every host in the push, across segments, in the same few minutes.

Likely objective: Deploy ransomware or a wiper to the whole domain at once.

Likely next move: Loss of the domain, loss of availability across segments, and loss of recovery data.

Possible indicators

- A domain controller starting SMB or RPC to many workstations.
- One admin host connecting to more than 20 hosts in minutes.
- The same service name or file on many hosts.
- A Group Policy change just before the activity.
- Many hosts contacting one new destination.

12. IMPACT · TA0040

12.3 Denial of Service or Link Saturation

PRIORITY **HIGH** ATT&CK T1498 Network Denial of Service | T1499 Endpoint Denial of Service

Critical if a link to a critical segment, or the gateway link, is affected.

TRIGGER

A sudden traffic spike on a link or interface, a service that stops responding, a high rate of connection attempts to one destination, or a flood of packets from one or many sources.

RESPONSE STEPS

1. **Identify the affected link or destination.**

   Router `show interfaces ethernet <port>` and compare packet and error counts with the same period yesterday.

   Splunk
   ```
   index=net dest_ip=<target_ip> | bin _time span=1m | stats count sum(bytes) as bytes dc(src_ip) as sources by _time | sort -count | head 20
   ```

2 **Identify the top sources.**

Splunk `index=net dest_ip=<target_ip> | stats count sum(bytes) as bytes by src_ip | sort -count | head 20`

Arkime `ip.dst==<target_ip>` then SPI View on `ip.src`, `protocols` and `port.dst`.

3 **Work out whether the sources are internal or external.**

Splunk `index=net dest_ip=<target_ip> NOT src_ip=<local_range> | stats count by src_ip | sort -count | head 20`

4 **Check for other events at the same time.**

Splunk Review events 5.1, 5.2 and 12.1 for the same period. A flood can distract from another action.

CONTAINMENT

- Block the flooding source addresses on the core routers.
- Limit the connection rate to the target on the core routers.
- If the source is internal, shut down the switch port and ask the host team to isolate the host.

ESCALATE IF

a link to a critical segment or the gateway link is affected, or the flood matches another event.

EVIDENCE TO RECORD

affected link and target, traffic counts, top sources, start and end times (UTC), search strings, interface counters.

NOTES

Applies to: core routers, the gateway, servers, any segment link.

At risk: Availability of the service or link, and communication between segments.

Likely objective: Disrupt service, or distract the defenders from another action.

Likely next move: A second action while the defenders are occupied, such as exfiltration or a configuration change.

Possible indicators

- A sudden rise in packets or sessions to one target.
- Many sources sending to one destination.
- Interface errors and drops rising on a link.
- A service that stops responding.
- A rise in half-open connections.

12. IMPACT · TA0040

12.4 Application Data Manipulation

PRIORITY HIGH ATT&CK T1565.001 Stored Data Manipulation | T1565.002 Transmitted Data Manipulation

Critical if changes alter financial, safety or operational records.

TRIGGER

Unusual write activity to business applications or databases from a client that does not normally write, changes outside business hours, or a host connecting to an application or database it does not normally use.

RESPONSE STEPS

1 **Find clients writing to the application or database.**

Splunk `index=net dest_ip=<db_server_ip> | stats sum(bytes_out) as sent sum(bytes_in) as received by src_ip | sort -sent`

Splunk `index=web method IN (POST,PUT,DELETE) dest_ip=<app_server_ip> | stats count by src_ip uri_path`

Arkime `ip.dst==<db_server_ip>` then SPI View on `ip.src` and `port.dst`.

2 **Compare with the approved clients.**

Logs The list of approved clients for each business application.

3 **Check for changes outside working hours.**

Splunk `index=net dest_ip=<db_server_ip> src_ip=<src_ip> | timechart span=1h sum(bytes_out) as sent`

4 **Check the accounts used.**

Logs Application and database audit logs for the accounts and the records changed.

5 **Check which segments reach the application.**

Splunk `index=net dest_ip=<app_server_ip> | stats count by src_ip | sort -count`

6 **Ask the application owner to compare records against backups.**

Host Ask the application owner for a record comparison against the last known-good backup.

CONTAINMENT

- Allow each business application to receive connections only from its approved clients and segments. Block everything else into it.
- Block the source host from connecting to the application and database. Ask the directory administrators to disable the account.
- Preserve database and application logs and flag the affected records for an integrity check. Restore from backup only after the access path is closed.

ESCALATE IF

critical records are affected, or the changes cannot be traced to an approved user.

EVIDENCE TO RECORD

source host and account, application or database, records changed, times (UTC), baseline comparison, search strings, log copies.

NOTES

Applies to: business application and database servers, and any client that connects to them.

At risk: The accuracy of business records. Decisions and operations that rely on them may use wrong data.

Likely objective: Disrupt operations or hide activity.

Likely next move: Other systems that use the same data, and the processes that depend on them.

Possible indicators

- Writes from a client that normally only reads.
- Changes outside working hours.
- A user workstation connecting directly to a database.
- Bulk updates or deletions.
- A new account using the application.

13 MITRE ATT&CK ENTERPRISE · NETWORK DEVICES
Network Devices and Boundary

These events cover the devices that carry traffic between segments and off the network. A compromise here affects every segment. Containment needs the incident lead's approval, as an action can cut off segments or services.

13. NETWORK DEVICES AND BOUNDARY · NETWORK DEVICES

13.1 Core Router: Management Access from an Unexpected Source

PRIORITY **CRITICAL** ATT&CK T1078 Valid Accounts | T1021.004 SSH | T1110 Brute Force

Always critical.

TRIGGER

SSH (port 22), web management (443), Telnet (23) or SNMP (161) to a core router from outside the IT admin range, a logon with the default account, or logons at unusual hours.

RESPONSE STEPS

1. **Find management traffic from other sources.**
   - Arkime: `ip.dst==<core_router_ip> && port.dst==[22,23,443,161] && ip.src!=<mgmt_range>`
   - Splunk: `index=net dest_ip=<core_router_ip> dest_port IN (22,23,443,161) NOT src_ip=<mgmt_range> | stats count by src_ip dest_port`
2. **Check logons.**
   - Splunk: `index=network_devices sshd "Accepted" | rex "Accepted \S+ for (?<user>\S+) from (?<src>\S+)" | stats count by host user src`
   - Router: `who` · `last -n 20`
3. **Check failed attempts.**
   - Splunk: `index=network_devices sshd ("Failed password" OR "Invalid user") | stats count by host`
4. **Check for Telnet.**
   - Arkime: `port.dst==23`
5. **Check what the source did next.**
   - Arkime: `ip.src==<src_ip> && ip.dst==<core_router_ip>` then SPI View on `ip.dst` and `port.dst`.
6. **Check for configuration changes since the first access.**
   - Router: See events 3.2 and 5.2.

CONTAINMENT

- Allow only one trusted management workstation to log in to the core routers. Block all other login and management traffic to them, including Telnet.
- Disable the default account and rotate all login passwords and SSH keys.
- With the incident lead's approval, block the source host from all management traffic and ask the host team to isolate it.

ESCALATE IF

always. Treat a login from an unexpected source as a possible full compromise of the router.

EVIDENCE TO RECORD

source address, account, login times (UTC), commands seen where logged, configuration copy with hash, search strings, Arkime session tags.

NOTES

Applies to: core routers.

At risk: The configuration, routing and rules between segments, and the credentials stored in the configuration.

Likely objective: Control of the network layer.

Likely next move: Rule changes (event 5.2), persistence (event 3.2) and tunnels (event 13.2).

Possible indicators

- Management traffic from a user segment.
- A login as the default vyatta account.
- Telnet to a router.
- Failed logons followed by a success.
- A login at an unusual hour.

13.2 Core Router: Tunnels, Redirection or Packet Capture

PRIORITY **CRITICAL** ATT&CK T1572 Protocol Tunneling | T1040 Network Sniffing | T1090 Proxy

Always critical.

TRIGGER

A new GRE (IP protocol 47), IPsec (protocol 50, UDP 500 and 4500), OpenVPN (UDP 1194) or WireGuard tunnel from a router to an unknown address, the router starting HTTP, HTTPS, SCP or FTP sessions to any host other than the update repository, traffic mirrored to another host, or packet capture running on a router.

RESPONSE STEPS

1. **Find tunnels.**
   - Arkime: `ip==<core_router_ip> && (ip.protocol==[47,50] || port.dst==[500,4500,1194,51820])`
   - Router: `show interfaces tunnel` · `show vpn ipsec sa` · `show interfaces openvpn`
2. **Find router-initiated outbound connections.**
   - Arkime: `ip.src==<core_router_ip> && port.dst==[21,22,80,443] && ip.dst!=<repository_ip>` then SPI View on `ip.dst`, `host.http` and `http.uri`.
   - Splunk: `index=net src_ip=<core_router_ip> NOT dest_ip=<repository_ip> NOT dest_port IN (53,123,514) | stats count sum(bytes_out) as bytes by dest_ip dest_port`
3. **Check for packet capture and mirroring.**
   - Router: `ps aux | grep -E "tcpdump|monitor"` · `show configuration commands | match "mirror"`
4. **Check for new address translation and port forwards.**
   - Router: `show configuration commands | match "nat"`
5. **Check for new listening ports on the router.**
   - Router: `sudo ss -tulpn`
   - Arkime: `ip.dst==<core_router_ip> && ip.src!=<mgmt_range>` then SPI View on `port.dst`. Any port other than routing and management is new.

CONTAINMENT

- Block the core routers from starting connections to anything except the logging, time, authentication and software update servers.
- Block the tunnel destination addresses at the gateway side of the core routers.
- Copy the configuration, then remove the unauthorised tunnels, mirrors and rules. If the router cannot be trusted, reinstall from a known-good image and restore a known-good configuration.

ESCALATE IF

always. A tunnel or capture on a core router can expose the traffic of every segment.

EVIDENCE TO RECORD

tunnel details and destination, router connections seen, configuration differences, copy of the configuration with hash, times (UTC), search strings, Arkime session tags.

NOTES

Applies to: core routers.

At risk: A copy of the traffic from every segment, and a path out that sensors may not see.

Likely objective: Copy or redirect traffic, and create a hidden path out of the network.

Likely next move: Exfiltration through the tunnel (section 11).

Possible indicators

- A new tunnel interface.
- A router connecting to a host that is not the update repository.
- tcpdump or a mirror rule on a router.
- A new address translation rule.
- A new listening port.